

FACULDADE ACADITI

MAC-PRO DFAC - Auditoria & Segurança Cibernética

VIRTUATECH

RELATÓRIO FINAL DE AUDITORIA (RFA)

RAI 001/2026

Alunos:

Anderson Williams
André Luiz Taques
Camila de Paula
Cristiano Carvalho
Daniel Lima Sousa
Flavio Carnieto
Marcela Apolinário
Odail Junior
Pablo Silva
Rodrigo Myotin

ABRIL/2026

FACULDADE ACADITI

MAC-PRO DFAC - Auditoria & Segurança Cibernética

VIRTUATECH

RELATÓRIO FINAL DE AUDITORIA (RFA)

RAI 001/2026

Trabalho apresentado da disciplina de Auditoria E Monitoramento de Redes, Perímetros e Sistemas como requisito parcial para obtenção do título de PÓS- GRADUAÇÃO LATO SENSU CIBERSEGURANÇA OFENSIVA, sob a orientação do Prof.º Fábio Sena

ABRIL/2026

RESUMO

Este Relatório Final de Auditoria (RFA), elaborado pela organização MAC-PRO DFAC, apresenta a avaliação detalhada dos controles internos de segurança da informação, governança e monitoramento de redes da VirtuaTech. O objetivo central do trabalho foi identificar vulnerabilidades e verificar o nível de aderência da infraestrutura tecnológica aos requisitos da norma internacional ISO/IEC 27001:2022. A metodologia aplicada estruturou-se em quatro fases: planejamento e preparação; execução com coleta técnica de evidências (inspeção de ativos pfSense, Active Directory e Graylog); análise de riscos e conformidade; e elaboração de plano de remediação. Os achados de auditoria revelaram um estado de maturidade de segurança imaturo e crítico, com a identificação de falhas severas, incluindo o uso de credenciais padrão em ativos de borda, exposição direta de serviços críticos (RDP) à rede pública, obsolescência de patches de segurança e inoperância do sistema de monitoramento SIEM para alertas pro-ativos. A análise de riscos, fundamentada em uma matriz de probabilidade e impacto, classificou diversas vulnerabilidades no quadrante crítico, indicando um risco residual inaceitável para a continuidade do negócio. Conclui-se que o processo de monitoramento de rede da VirtuaTech não é efetivo no estado atual, sendo mandatória a implementação imediata de uma nova arquitetura de segurança baseada em defesa em profundidade, segregação de redes por VLANs e autenticação multifator (MFA).

Palavras-chave: Auditoria de Segurança. ISO/IEC 27001:2022. VirtuaTech. Monitoramento de Redes. Gestão de Riscos. Compliance.

ABSTRACT

This Final Audit Report (FAR), developed by the MAC-PRO DFAC organization, presents a detailed evaluation of information security internal controls, governance, and network monitoring at VirtuaTech. The primary objective of the study was to identify vulnerabilities and verify the technological infrastructure's level of adherence to the ISO/IEC 27001:2022 international standard requirements. The applied methodology was structured into four phases: planning and preparation; execution with technical evidence collection (inspection of pfSense, Active Directory, and Graylog assets); risk and compliance analysis; and the development of a remediation plan. The audit findings revealed an immature and critical security maturity state, identifying severe failures, including the use of default credentials on perimeter assets, direct

exposure of critical services (RDP) to the public network, obsolescence of security patches, and the inoperability of the SIEM monitoring system for proactive alerts. The risk analysis, based on a probability and impact matrix, classified several vulnerabilities in the critical quadrant, indicating an unacceptable residual risk for business continuity. It is concluded that VirtuaTech's network monitoring process is not effective in its current state, making the immediate implementation of a new security architecture based on defense in depth, network segregation via VLANs, and multi-factor authentication (MFA) mandatory.

Keywords: Security Audit. ISO/IEC 27001:2022. VirtuaTech. Network Monitoring. Risk Management. Compliance.

Auditoria Interna - MAC-PRO DFAC - Auditoria & Segurança Cibernética

RELATÓRIO FINAL DE AUDITORIA (RFA)

Unidades Examinadas: VIRTUATECH

RAI 001/2026

Missão MAC-PRO DFAC

Nossa missão é garantir que a infraestrutura tecnológica de nossos clientes seja mais segura e resiliente. Através de um compromisso com o rigor profissional e as normas internacionais, transformamos a auditoria em um ativo estratégico para assegurar a integridade, confidencialidade e a disponibilidade, utilizando os frameworks de segurança mais exigentes do mercado.

LISTA DE SIGLAS E ABREVIATURAS

- AD (Active Directory): Serviço de diretório da Microsoft para gerenciamento de identidades e acessos.
- CVE (Common Vulnerabilities and Exposures): Glossário de vulnerabilidades de segurança da informação conhecidas publicamente.
- DNS (Domain Name System): Sistema que traduz nomes de domínio em endereços IP.
- HTTP (Hypertext Transfer Protocol): Protocolo base para a troca de informações na web.
- HTTPS (Hypertext Transfer Protocol Secure): Versão segura do HTTP que utiliza criptografia SSL/TLS.
- ICMP (Internet Control Message Protocol): Protocolo utilizado para comunicar erros e informações operacionais (comumente usado em comandos “ping”).
- IP (Internet Protocol): Protocolo de comunicação da camada de rede.
- ISO (International Organization for Standardization): Organização internacional de padronização.
- MitM (Man-in-the-Middle): Tipo de ataque onde o invasor intercepta a comunicação entre duas partes.
- NOC (Network Operations Center): Centro de Operações de Rede.
- RDP (Remote Desktop Protocol): Protocolo de desktop remoto para acesso a servidores e estações Windows.
- RFA (Relatório Final de Auditoria): Documento conclusivo do processo de auditoria.
- SIEM (Security Information and Event Management): Tecnologia que fornece análise em tempo real de alertas de segurança gerados por aplicações e hardware.
- SOC (Security Operations Center): Centro de Operações de Segurança.
- SSL/TLS (Secure Sockets Layer / Transport Layer Security): Protocolos de segurança que garantem a privacidade e a integridade dos dados na internet.
- WAN (Wide Area Network): Rede de longa distância (comumente referente à internet pública em firewalls).

GLOSSÁRIO DE TERMOS TÉCNICOS

- Ataque de Força Bruta (Brute Force): Método de invasão que consiste em tentar adivinhar senhas por meio de sucessivas tentativas automatizadas até encontrar a correta.
- Audit Trail (Trilha de Auditoria): Registros cronológicos que permitem reconstruir a sequência de eventos que afetaram uma operação ou transação.
- Backdoor: “Porta dos fundos”; uma falha ou método de acesso criado para permitir que um invasor retorne ao sistema de forma oculta.
- Criptografia: Técnica de transformar informações em um código ilegível para impedir que pessoas não autorizadas compreendam os dados em caso de interceptação.
- End-of-Life (EOL): Termo usado para indicar que um software ou hardware não recebe mais atualizações do fabricante, tornando-se um risco crítico de segurança.
- Firewall: Dispositivo de segurança que atua como uma barreira entre a rede interna da empresa e a internet, filtrando o que pode entrar ou sair.
- Interface de Gerenciamento: Painel de controle de um sistema. Se exposto incorretamente, permite que um invasor altere configurações vitais de toda a rede.
- Log (Registro de Eventos): Arquivo digital que anota tudo o que acontece em um sistema, essencial para descobrir como uma invasão ocorreu.
- Não Conformidade: Descumprimento de um requisito estabelecido por uma norma (como a ISO 27001) ou política interna da empresa.
- Nivelamento de Privilégios: Princípio de conceder ao usuário apenas os acessos estritamente necessários para sua função, evitando que o comprometimento de uma conta comum afete todo o sistema.
- Pentest (Teste de Intrusão): Ataque simulado autorizado para avaliar a segurança da infraestrutura e identificar falhas antes que criminosos as explorem.
- Vulnerabilidade: Uma fraqueza ou brecha de segurança que pode ser explorada por uma ameaça para causar danos ou acesso não autorizado.

CARTA DE APRESENTAÇÃO

MAC-PRO DFAC - Auditoria & Segurança Cibernética

Data: 27 de abril de 2026

Assunto: Apresentação de Soluções em Auditoria e Conformidade Tecnológica

À Diretoria e Stakeholders,

É com foco em resiliência e integridade digital que apresentamos a MAC-PRO DFAC. Nossa organização nasce da união de especialistas dedicados a elevar os padrões de segurança em ambientes de dados complexos.

O nome de nossa empresa reflete nossa metodologia de trabalho:

- MAC (Media Access Control): Representa nossa especialidade em controle de acesso e governança de perímetros digitais.
- PRO: Simboliza o compromisso com a conformidade técnica (Compliance) e o rigor profissional exigido pelas normas internacionais.
- DFAC: Nossa unidade de resposta e análise, focada em diagnóstico, fiscalização e auditoria contínua.

Na MAC-PRO DFAC, não enxergamos a auditoria apenas como um processo de verificação, mas como um ativo estratégico. Em um cenário onde as ameaças cibernéticas evoluem rapidamente, nosso objetivo é garantir que a infraestrutura de nossos clientes seja não apenas funcional, mas também segura e em conformidade com os principais frameworks e normas do mercado.

Nossos serviços abrangem desde a análise de vulnerabilidades até a certificação de processos internos, promovendo maior controle sobre as informações e transparência na gestão de acessos.

Estamos prontos para assegurar o futuro digital de sua operação.

Atenciosamente,

Conselho de Sócios Diretores:

André T., Anderson W., Camila P., Cristiano C., Daniel S., Flavio C., Marcela C., Odail J., Pablo S. e Rodrigo M.

MAC-PRO DFAC - Controle de Acesso. Conformidade Técnica. Segurança Absoluta.

AVISO DE NÃO DIVULGAÇÃO

Este documento contém informações sensíveis e privilegiadas sobre a infraestrutura tecnológica da VirtuaTech. O conteúdo deste relatório é para uso exclusivo das partes interessadas autorizadas pela MAC-PRO DFAC e pela diretoria da VirtuaTech. É estritamente proibida a reprodução total ou parcial, bem como a partilha com terceiros sem autorização prévia por escrito, sob pena de violação das políticas de segurança e da LGPD.

Sumário

RESUMO	4
ABSTRACT	4
Missão MAC-PRO DFAC.....	2
LISTA DE SIGLAS E ABREVIATURAS.....	3
GLOSSÁRIO DE TERMOS TÉCNICOS	4
CARTA DE APRESENTAÇÃO.....	5
AVISO DE NÃO DIVULGAÇÃO	6
Índice de Ilustrações.....	9
1. INTRODUÇÃO	10
2. METODOLOGIA.....	11
2.1 Ciclo de Auditoria	11
2.2 Técnicas de Auditoria Aplicadas.....	11
2.3 Critérios de Avaliação de Risco	12
3. CONTEXTUALIZAÇÃO DA ORGANIZAÇÃO (VIRTUATECH).....	13
3.1 Estrutura de Governança de TI e Segurança	13
3.2 Organograma Funcional da Auditoria	13
3.3 Ativos Críticos Auditados (Baseado no Lab).....	13
4. PLANEJAMENTO DE EXECUÇÃO DA AUDITORIA - VIRTUATECH.....	15
Fase 1: Planejamento e Preparação.....	15
Fase 2: Execução – Varredura e Coleta de Evidências	15
Fase 3: Análise de Dados, Riscos e Conformidade	16
Fase 4: Elaboração do Relatório Final de Auditoria (RFA) e Plano de Ação	16
5. COLABORADORES ENVOLVIDOS.....	17
6. ESCOPO DA AUDITORIA.....	18
7. EVIDÊNCIAS IDENTIFICADAS.....	18
7.1. CONFORMIDADES	18
ID DO ACHADO: AUD-001	18
ID DO ACHADO: AUD-002	19
7.2. NÃO CONFORMIDADES	20
ID DO ACHADO: AUD-003	20
ID DO ACHADO: AUD-004	21
ID DO ACHADO: AUD-005	22
ID DO ACHADO: AUD-006	23
ID DO ACHADO: AUD-007	23
ID DO ACHADO: AUD-008	24

ID DO ACHADO: AUD-009	25
ID DO ACHADO: AUD-010	26
ID DO ACHADO: AUD-011	28
ID DO ACHADO: AUD-012	29
ID DO ACHADO: AUD-013	30
ID DO ACHADO: AUD-014	31
ID DO ACHADO: AUD-015	32
ID DO ACHADO: AUD-016	33
8. CADEIA DE CUSTÓDIA - Auditoria VirtuaTech (RAI 001/2026).....	37
9. ANÁLISE DE RISCOS	40
9.1. Interpretação da Matriz de Risco (Heat Map).....	41
10. CONCLUSÃO	43
11. RECOMENDAÇÕES GERAIS	44
12. ARQUITETURA DE SEGURANÇA RECOMENDADA	45
13. QUADRO COMPARATIVO: ATUAL VS. DESEJADO.....	45
14. MATRIZ DE REQUISITOS	48
15. PRIORIZAÇÃO	50
16. REFERÊNCIAS.....	52
Anexos:.....	52
ANEXOS	

Índice de Ilustrações

Figura 1. Estrutura Organizacional da VirtuaTech.....	17
Figura 2. ID DO ACHADO: AUD-001.....	18
Figura 3. ID DO ACHADO: AUD-002.....	19
Figura 4. ID DO ACHADO: AUD-003.....	20
Figura 5. ID DO ACHADO: AUD-004.....	21
Figura 6. ID DO ACHADO: AUD-005.....	22
Figura 7. ID DO ACHADO: AUD-006.....	23
Figura 8. ID DO ACHADO: AUD-007.....	24
Figura 9. ID DO ACHADO: AUD-008.....	25
Figura 10. ID DO ACHADO: AUD-009.....	26
Figura 11. ID DO ACHADO: AUD-010.....	27
Figura 12. ID DO ACHADO: AUD-011.....	28
Figura 13. ID DO ACHADO: AUD-012.....	29
Figura 14. ID DO ACHADO: AUD-013.....	30
<i>Figura 15. ID DO ACHADO: AUD-014</i>	<i>31</i>
Figura 16. ID DO ACHADO: AUD-015.....	33
Figura 17. ID DO ACHADO: AUD-016.....	34
Figura 18. Gráfico Matriz de Risco	41
Figura 19. Topologia de Rede recomendada	46

RELATÓRIO FINAL DE AUDITORIA (RFA) - VIRTUATECH

1. INTRODUÇÃO

Objetivo da auditoria: Os trabalhos de auditoria tiveram como objetivo avaliar os controles internos relativos à gestão, operação e monitoramento de redes e sistemas da VirtuaTech. A auditoria busca identificar não conformidades, assegurar o alinhamento com as boas práticas da norma ISO/IEC 27001 e apontar vulnerabilidades que possam impactar a integridade, confidencialidade e disponibilidade dos ativos de informação.

Escopo: Em estrito alinhamento com os objetivos da avaliação, o escopo desta auditoria foi rigorosamente delimitado às práticas, ferramentas e resultados associados ao monitoramento de redes e sistemas. Qualquer processo fora deste escopo, como normas de qualidade (ex: ISO 9001) ou gestão ambiental (ex: ISO 14000), foram deliberadamente ignorados para garantir foco na análise de segurança e resiliência.

Contextualização do ambiente auditado: A VirtuaTech é uma gigante do setor de Tecnologia da Informação que recentemente foi sacudida por um evento de segurança da informação preocupante. Em resposta, a alta gestão solicitou esta auditoria independente para explorar as entranhas de seus sistemas, avaliando a eficácia do monitoramento ativo, o tratamento de logs e a proteção do perímetro de rede. O ambiente avaliado é composto por ativos críticos que sustentam a operação da organização.

2. METODOLOGIA

A execução desta auditoria baseou-se em técnicas de observabilidade e avaliação de conformidade, incluindo análise documental de políticas internas, inspeção de configurações de rede e varredura ativa de vulnerabilidades no perímetro. O processo foi estruturado em quatro fases principais:

2.1 Ciclo de Auditoria

1. **Planejamento e Preparação:** Definição do escopo, identificação dos ativos críticos da VirtuaTech e análise da documentação técnica prévia.
2. **Execução e Coleta de Evidências:** Fase operacional de testes no ambiente de rede e sistemas (pfSense, Graylog, Active Directory).
3. **Análise e Avaliação:** Confronto das evidências coletadas com a política de monitoramento da VirtuaTech, alinhado às boas práticas da ISO 27001 para identificação de não conformidades.
4. **Relatório e Plano de Ação:** Consolidação dos achados, classificação de riscos e proposição de medidas mitigadoras.

2.2 Técnicas de Auditoria Aplicadas

Para garantir a integridade dos resultados, foram aplicados os seguintes testes:

- **Testes de Conformidade (Observância):** Realizados para obter segurança razoável de que os controles internos estabelecidos pela gestão estão em efetivo funcionamento e cumprem as normas da ISO 27001. Exemplo: Verificação da existência de políticas de senhas.
- **Testes Substantivos:** Procedimentos visando obter evidências suficientes sobre a validade dos dados e a segurança dos sistemas. Incluem:
 - **Inspeção Física e Lógica:** Análise direta de configurações de regras de firewall e logs de sistema.
 - **Observação:** Acompanhamento dos fluxos de dados e tentativas de acesso.
 - **Rastreamento:** Verificação da origem e destino de conexões suspeitas (ex: tráfego RDP na WAN).

2.3 Critérios de Avaliação de Risco

Os riscos foram classificados com base na matriz de Probabilidade x Impacto, seguindo a escala de 1 a 5, onde os resultados determinam o nível de priorização das recomendações técnicas.

3. CONTEXTUALIZAÇÃO DA ORGANIZAÇÃO (VIRTUATECH)

A VirtuaTech é uma organização cujo modelo de negócio depende criticamente da integridade e disponibilidade de sua infraestrutura de rede e processamento de dados. A empresa possui uma estrutura de governança de TI centralizada, composta pelas seguintes áreas e responsabilidades:

3.1 Estrutura de Governança de TI e Segurança

A governança da informação na VirtuaTech é desenhada para suportar as operações críticas através de três pilares fundamentais:

- Gerência de Infraestrutura e Redes: Responsável pela administração do perímetro de segurança (Firewall pfSense) e pela conectividade interna e externa.
- Gestão de Identidade e Acessos (IAM): Área focada na administração do Controlador de Domínio (Active Directory), responsável pela custódia das credenciais de usuários e privilégios administrativos.
- Centro de Operações de Segurança (SOC) / Monitoramento: Responsável pela ingestão, análise e resposta a incidentes através do concentrador de logs (Graylog).

3.2 Organograma Funcional da Auditoria

Para fins deste relatório, a estrutura hierárquica auditada está organizada conforme abaixo:

- Diretoria de Tecnologia (CTO): Responsável pelas decisões estratégicas e aceitação de riscos residuais.
- Administração de Sistemas: Executores das configurações lógicas no AD e servidores.
- Operadores de Segurança: Analistas responsáveis pela observação de eventos no SIEM.

3.3 Ativos Críticos Auditados (Baseado no Lab)

É importante descrever os ativos da VirtuaTech como “ativos de negócio”:

- Controlador de Domínio (192.168.161.110): Repositório central de identidades. Sua queda ou comprometimento representa a interrupção total das operações da VirtuaTech.

- Concentrador de Logs Graylog (192.168.161.50): Ativo crítico para conformidade e perícia forense.
- Firewall Perimetral pfSense (192.168.161.1): Primeira linha de defesa contra ameaças externas e gateway da rede WAN.

4. PLANEJAMENTO DE EXECUÇÃO DA AUDITORIA - VIRTUATECH

Período de Execução: 11/04/2026 a 03/05/2026

Objetivo: Avaliar o monitoramento de redes, perímetros e sistemas (AD, Graylog, pfSense) em conformidade com a ISO/IEC 27001.

Fase 1: Planejamento e Preparação

Período: 11/04/2026 a 15/04/2026

Objetivo: Definir o escopo exato, organizar o cronograma interno, identificar os requisitos normativos e realizar a revisão preliminar da documentação da VirtuaTech (Política de Monitoramento).

- Rodrigo Myotin (Auditor Líder): Responsável por coordenar a equipe, definir o cronograma e garantir que o escopo se mantenha delimitado aos controles de monitoramento.
- Camila de Paula: Responsável pela análise documental preliminar, mapeando as exigências da “Política de Monitoramento de Redes e Sistemas da VirtuaTech” para criar a lista de requisitos que guiará os testes práticos.

Fase 2: Execução – Varredura e Coleta de Evidências

Período: 16/04/2026 a 22/04/2026

Objetivo: Acessar o ambiente e realizar a coleta técnica de dados, logs e configurações dos ativos definidos no escopo.

- Pablo Gomes Sales da Silva, Odail Della Niesi Junior e André Luiz Taques (Equipe de Perímetro e Rede): Focados no Firewall pfSense (192.168.161.1). Devem verificar regras de roteamento, bloqueios e confirmar tecnicamente a ausência/presença de envio de logs (Syslog) para o concentrador.
- Flavio Augusto Casini Carnieto e Cristiano Carvalho (Equipe de Sistemas e Observabilidade): Focados no Controlador de Domínio AD (192.168.161.110) e no SIEM Graylog (192.168.161.50:9000). Devem coletar evidências de eventos de login (ex: ID 4625), verificar as configurações de retenção e a ausência de alertas pró-ativos.

Fase 3: Análise de Dados, Riscos e Conformidade

Período: 23/04/2026 a 27/04/2026

Objetivo: Analisar dados brutos para gerar achados de auditoria fundamentados, assegurando a conformidade técnica com a Política de Segurança da Informação da empresa e com a norma ISO 27001.

- Anderson Williams e Daniel Lima Sousa: Atuarão na análise crítica das evidências levantadas pela fase anterior. Devem avaliar o impacto de negócio das falhas (ex: ponto cego no perímetro, ausência de retenção histórica) e preencher a Matriz de Requisitos, classificando o risco (Baixo, Médio, Alto, Crítico) de cada vulnerabilidade encontrada.

Fase 4: Elaboração do Relatório Final de Auditoria (RFA) e Plano de Ação

Período: 28/04/2026 a 01/05/2026

Objetivo: Redigir o documento final (RFA) de forma colaborativa, utilizando linguagem formal, clara e objetiva para apresentar os achados à alta gestão.

- Odail Della Niesi Junior: Responsável por redigir a Introdução, Escopo, Metodologia e a sumarização do Resumo Executivo.
- Marcela Apolinário Celestino: Responsável por estruturar os Achados de Auditoria (ID, Descrição, Evidência, Impacto) e propor as Recomendações (Plano de Ação) apontando soluções viáveis (ex: habilitar Syslog, configurar retenção a longo prazo).

5. COLABORADORES ENVOLVIDOS

Figura 1. Estrutura Organizacional da VirtuaTech



Fonte: Laboratório - AUD - Auditoria de Redes, Perímetros e sistemas (2026)

6. ESCOPO DA AUDITORIA

Os testes, observações e coletas de evidências concentraram-se na camada de coleta de dados e monitoramento de perímetro, avaliando especificamente os seguintes ativos:

- **Perímetro de Rede:** Firewall pfSense (IP 192.168.161.1).
- **Gestão de Identidade e Acesso:** Controlador de Domínio (Active Directory).
- **Armazenamento e Análise de Logs:** Servidor de centralização de logs e eventos (Graylog).

7. EVIDÊNCIAS IDENTIFICADAS

7.1. CONFORMIDADES

ID DO ACHADO: AUD-001

Controle ISO 27001:2022: A.8.15 -Registro de Eventos

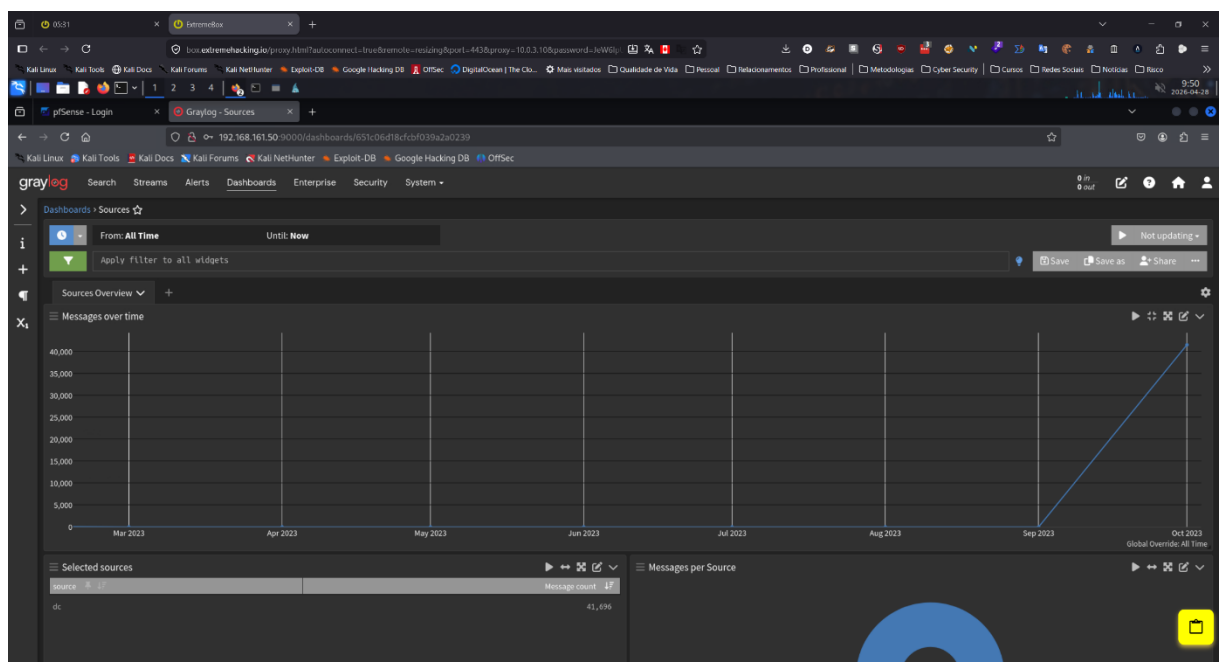
Classificação: CONFORME

Requisito avaliado: Presença de solução centralizada para registro e monitoramento de logs.

Evidência coletada: Existência de servidor Graylog 4.0 configurado para ingestão de mensagens via GELF UDP, com registros históricos de atividades do controlador de domínio.

Arquivo de evidência:

Figura 2. ID DO ACHADO: AUD-001



Fonte: Captura de tela realizada pelo Auditor (2026)

Hash SHA-256: SHA256 hash de 2026-04-28 09_48_11-ExtremeBox -Mozilla Firefox.png:

b0e4d924ce00a21e7afc8dbc2d47b5796c6f7787bacac43ef596c03606fbde78

Data/hora da coleta: 28/04/2026 - 09:50 - UTC-3

Coletado por: Odail Della Niesi Junior

Impacto: Permite a centralização de eventos, requisito fundamental para a rastreabilidade e análise de incidentes.

Recomendação: Elogia-se a escolha da ferramenta; recomenda-se agora garantir a sustentabilidade da ingestão.

Prazo: N/A

ID DO ACHADO: AUD-002

Controle ISO 27001:2022: A.8.20 -Segurança de Redes

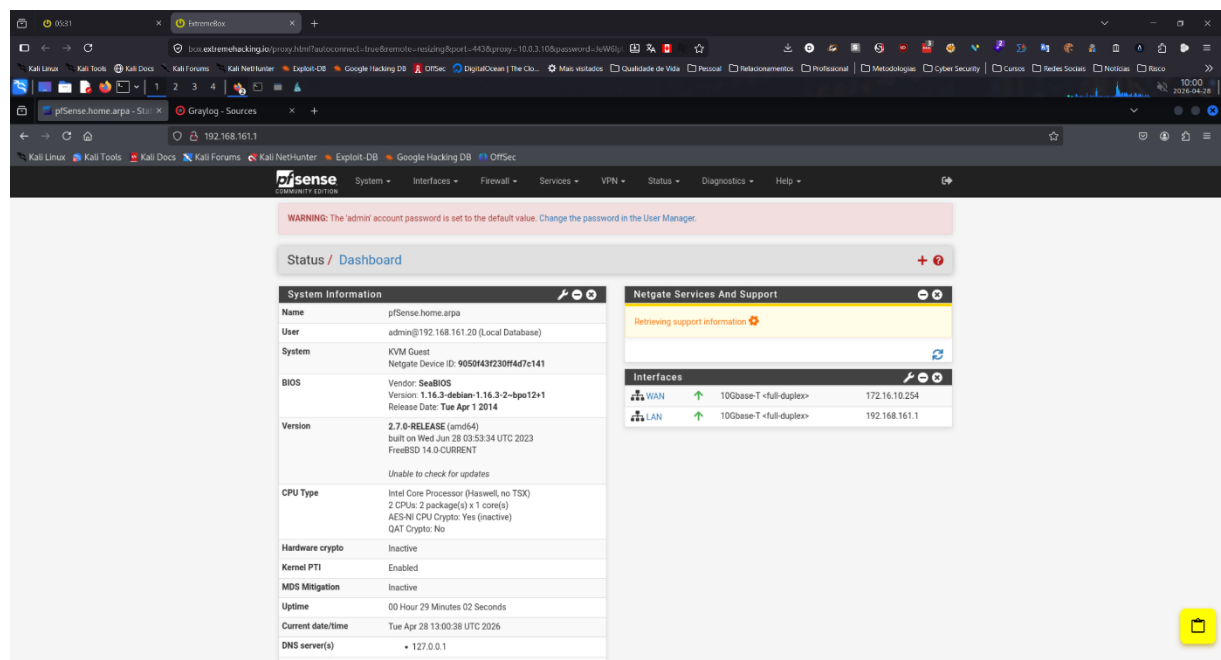
Classificação: CONFORME

Requisito avaliado: Presença de ativos de segurança perimetral (Firewall).

Evidência coletada: O ambiente dispõe de um Firewall pfSense 2.7.0 operacional, atuando como gateway da rede interna (192.168.161.1).

Arquivo de evidência:

Figura 3. ID DO ACHADO: AUD-002



Fonte: Captura de tela realizada pelo Auditor (2026)

Hash SHA-256: SHA256 hash de 2026-04-28 09_57_56-ExtremeBox -Mozilla Firefox.png:

dffe7d009cd0a158712a5e6f6d8f636868637d3bff0c4f0299408d38c78690b4

Data/hora da coleta: 28/04/2026 - 10:00 - UTC-3

Coletado por: Odail Della Niesi Junior

Impacto: O ativo provê a capacidade técnica necessária para a filtragem de pacotes e proteção de borda.

Recomendação: Manter a tecnologia; focar na correção das regras de filtragem (ver NC-A).

Prazo: N/A

7.2. NÃO CONFORMIDADES

ID DO ACHADO: AUD-003

Controle ISO 27001:2022: A.8.20 -Segurança de Redes

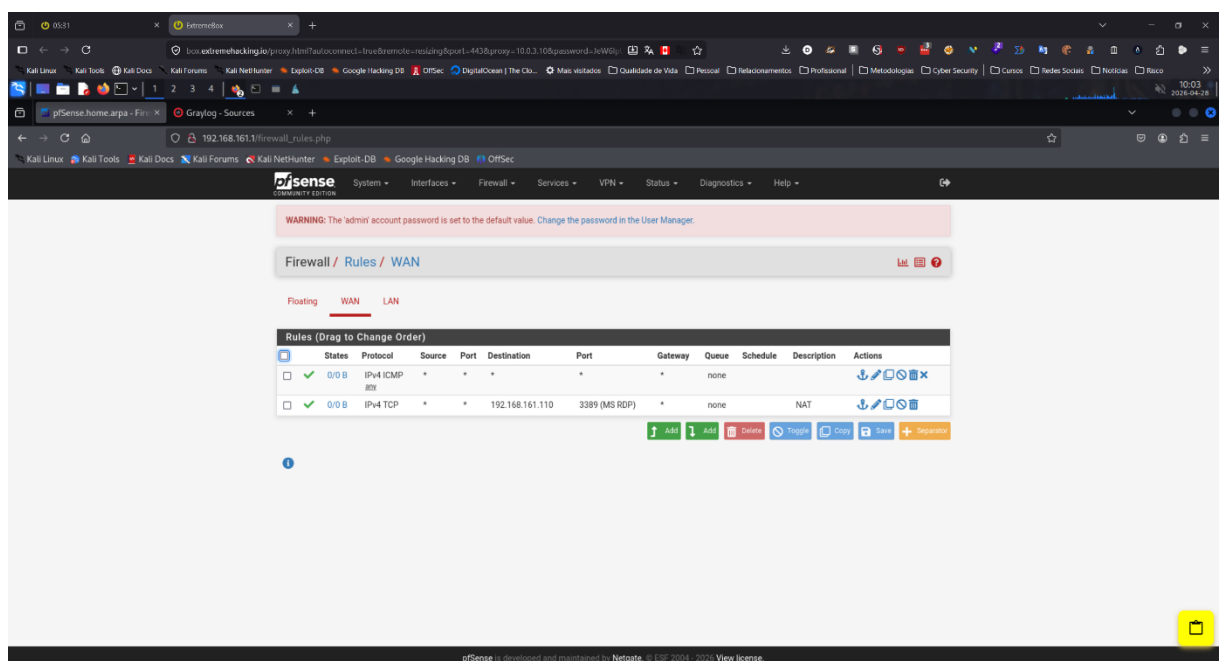
Classificação: NÃO CONFORME ALTA

Requisito avaliado: Controle de tráfego de rede e restrição de serviços sensíveis à internet.

Evidência coletada: O pfSense possui uma regra de NAT/Firewall permitindo tráfego TCP na porta 3389 (MS RDP) diretamente da WAN para o Controlador de Domínio (192.168.161.110).

Arquivo de evidência:

Figura 4. ID DO ACHADO: AUD-003



Fonte: Captura de tela realizada pelo Auditor (2026)

Hash SHA-256: SHA256 hash de 2026-04-28 10_00_57-ExtremeBox -Mozilla Firefox.png:

f723f8e797c38a1b5ed5c0d46b7629e203e4479a019715383135578a2c48ba10

Data/hora da coleta: 28/04/2026 - 10:03 - UTC-3

Coletado por: Odail Della Niesi Junior

Impacto: Exposição direta do coração do domínio a ataques de força bruta e exploração de vulnerabilidades de execução remota de código (RCE).

Recomendação: Desativar imediatamente a regra de encaminhamento de porta 3389 para a WAN. Implementar VPN para acesso remoto.

Prazo: NC-ALTA: 30 a 90 dias.

ID DO ACHADO: AUD-004

Controle ISO 27001:2022: A.8.5 -Autenticação Segura

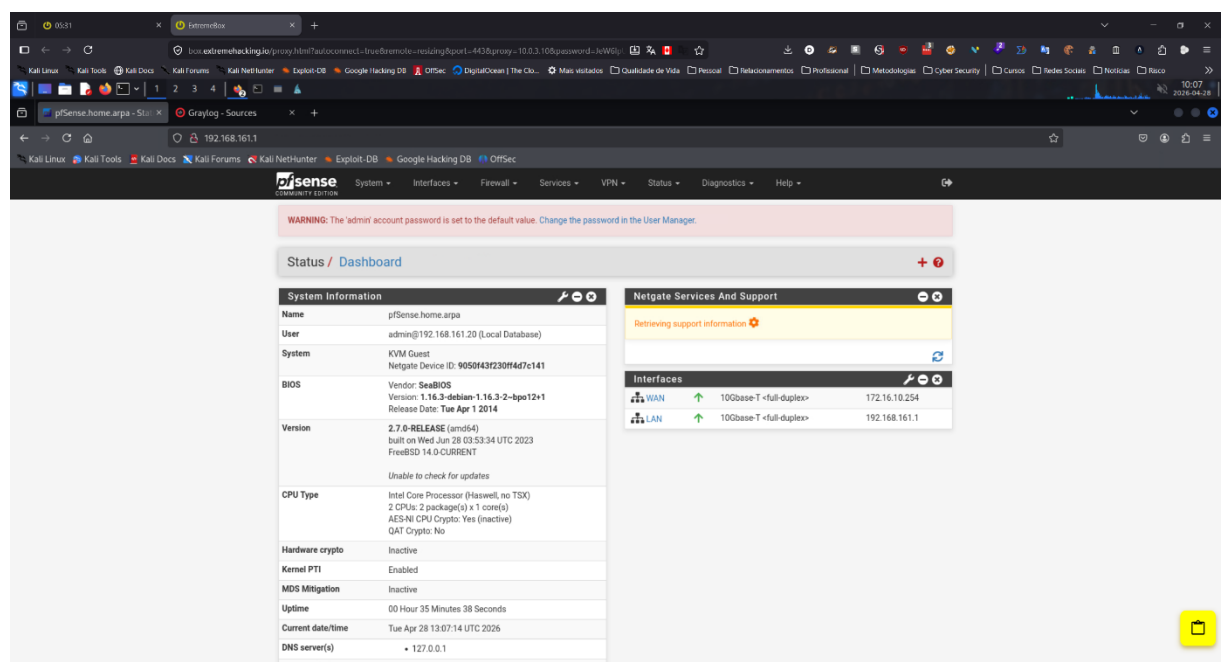
Classificação: NÃO CONFORME ALTA

Requisito avaliado: Uso de credenciais fortes e proibição de senhas padrão em ativos críticos.

Evidência coletada: O firewall pfSense está operando com a senha administrativa padrão (admin/pfsense).

Arquivo de evidência:

Figura 5. ID DO ACHADO: AUD-004



Fonte: Captura de tela realizada pelo Auditor (2026)

Hash SHA-256: SHA256 hash de 2026-04-28 10_04_32-ExtremeBox -Mozilla Firefox.png:
d90749bae3a9f16234843c6431614162df6d7d1acb688efe96e15d83c323cbe0

Data/hora da coleta: 28/04/2026 - 10:07 - UTC-3

Coletado por: Odail Della Niesi Junior

Impacto: Permite o comprometimento total e imediato de toda a rede por qualquer usuário que conheça as senhas de fábrica ou do manual.

Recomendação: Alterar as senhas para padrões complexos (>12 caracteres). Implementar MFA para contas administrativas.

Prazo: NC-ALTA: 30 a 90 dias.

ID DO ACHADO: AUD-005

Controle ISO 27001:2022: A.8.5 -Autenticação Segura

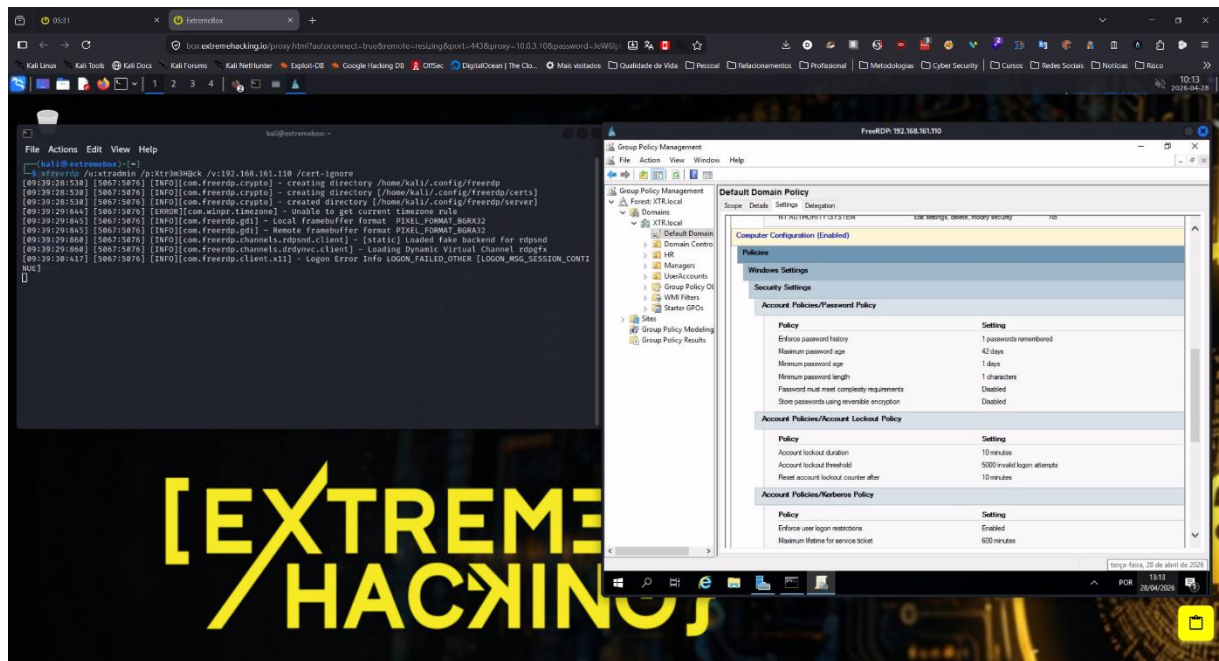
Classificação: NÃO CONFORME ALTA

Requisito avaliado: Configuração de diretrizes de senhas e bloqueio de contas.

Evidência coletada: A GPO de domínio define o comprimento mínimo da senha como 1 caractere, complexidade desabilitada e limite de bloqueio de conta em 5000 tentativas.

Arquivo de evidência:

Figura 6. ID DO ACHADO: AUD-005



Fonte: Captura de tela realizada pelo Auditor (2026)

Hash SHA-256: SHA256 hash de 2026-04-28 10_11_09-ExtremeBox -Mozilla Firefox.png:

a2b29e9e1d19aa761dd4c0f8a7779fd99fe0989ffaf9537c81d3c113c082acca

Data/hora da coleta: 28/04/2026 - 10:13 - UTC-3

Coletado por: Odail Della Niesi Junior

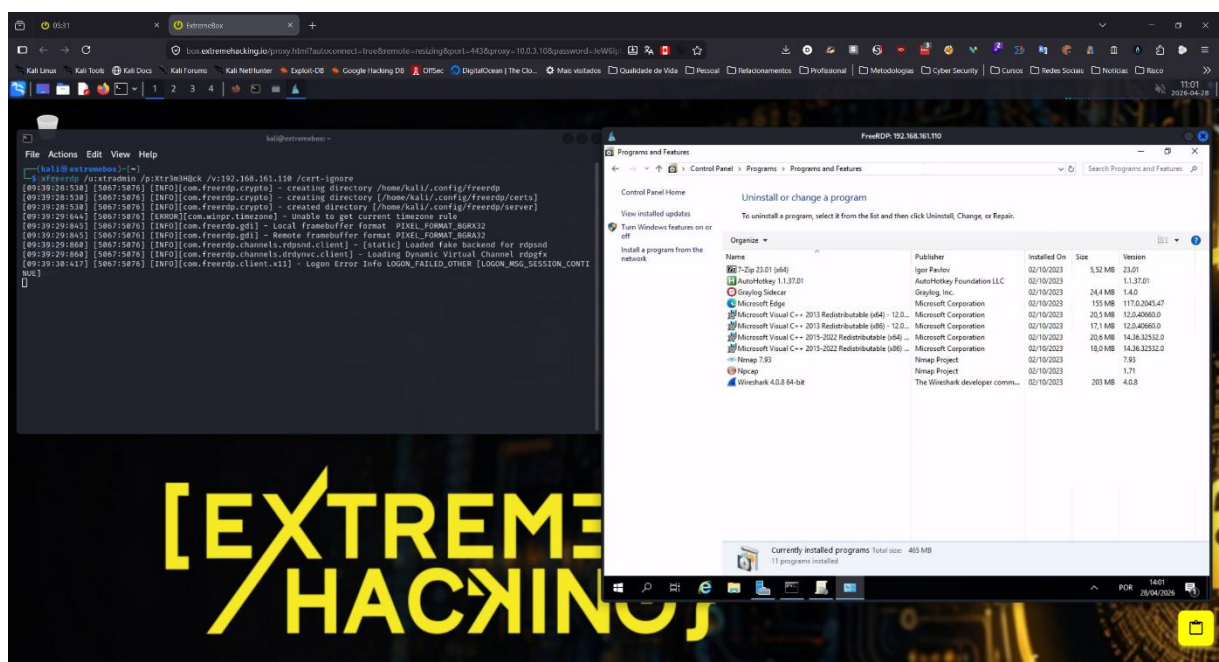
Impacto: Facilita ataques de força bruta, permitindo milhões de tentativas sem bloqueio de conta e aceitando senhas triviais.

Recomendação: Ajustar GPO: Senha mín. 12 chars, habilitar complexidade e lockout threshold para 5 tentativas.

Prazo: NC-ALTA: 30 a 90 dias.

ID DO ACHADO: AUD-006**Controle ISO 27001:2022:** A.8.19 -Instalação de Software em Sistemas Operacionais**Classificação:** NÃO CONFORME ALTA**Requisito avaliado:** Restrição de ferramentas não autorizadas e de uso duplo em servidores críticos.**Evidência coletada:** O Controlador de Domínio possui ferramentas de hacking instaladas: Nmap 7.93, Npcap e Wireshark 4.0.8.**Arquivo de evidência:**

Figura 7. ID DO ACHADO: AUD-006



Fonte: Captura de tela realizada pelo Auditor (2026)

Hash SHA-256: SHA256 hash de 2026-04-28 10_58_38-ExtremeBox -Mozilla Firefox.png:

8ae74f37fe26803a3807ee90c5782f73f1cc3ad63266bf0087f5b1c9138dc6c0

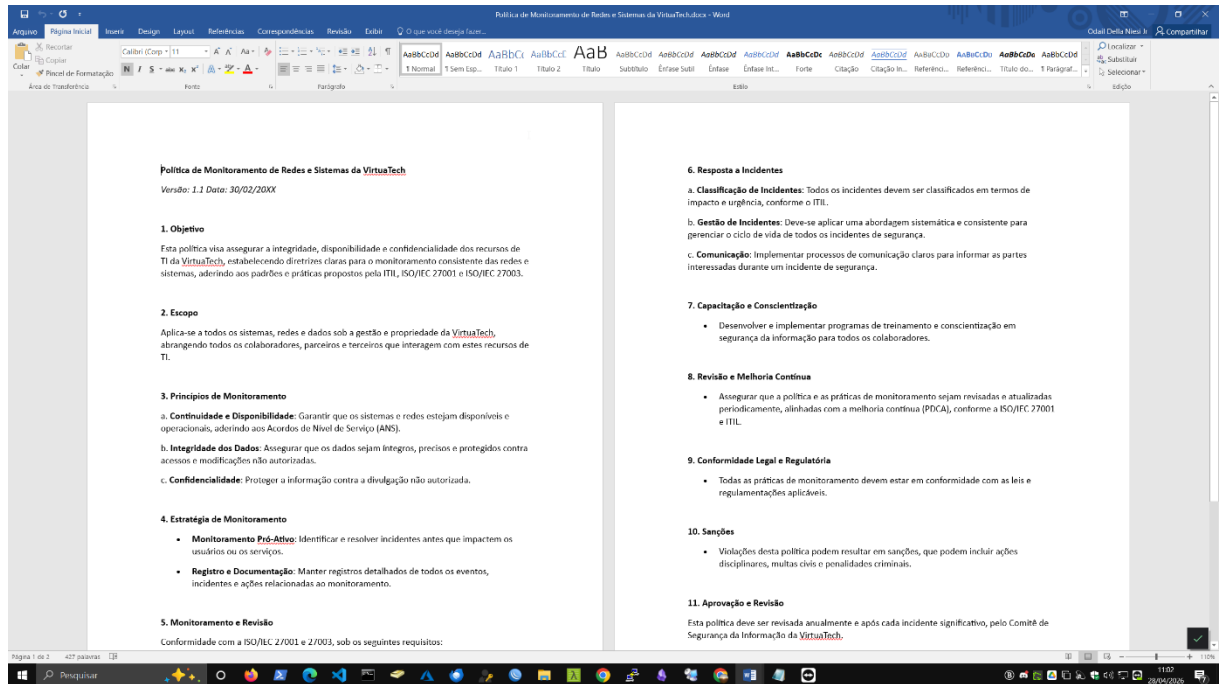
Data/hora da coleta: 28/04/2026 - 11:01 - UTC-3**Coletado por:** Odail Della Niesi Junior**Impacto:** Fornece a um atacante que obtenha acesso ao servidor todas as ferramentas necessárias para movimentação lateral e sniffing de rede.**Recomendação:** Remover imediatamente todos os softwares de sniffing e varredura do DC.**Prazo:** NC-ALTA: 30 a 90 dias.**ID DO ACHADO: AUD-007****Controle ISO 27001:2022:** A.5.5 - Informação Documentada**Classificação:** NÃO CONFORME BAIXA

Requisito avaliado: Precisão e revisão da documentação normativa.

Evidência coletada: A Política de Monitoramento apresenta uma data de revisão inexistente: “30 de fevereiro de 20XX”.

Arquivo de evidência:

Figura 8. ID DO ACHADO: AUD-007



Fonte: Captura de tela realizada pelo Auditor (2026)

Hash SHA-256: SHA256 hash de 2026-04-28 11_02_29-.png:

1a39f7b7d0e31c24fe3273e3db304618c221836845a91acb63d4aa533fee4ff4

Data/hora da coleta: 28/04/2026 - 11:02 - UTC-3

Coletado por: Odail Della Niesi Junior

Impacto: Falha na integridade documental, demonstrando falta de revisão crítica nas políticas.

Recomendação: Corrigir o erro cronológico e estabelecer fluxo de revisão anual.

Prazo: NC-BAIXA: 15 dias.

ID DO ACHADO: AUD-008

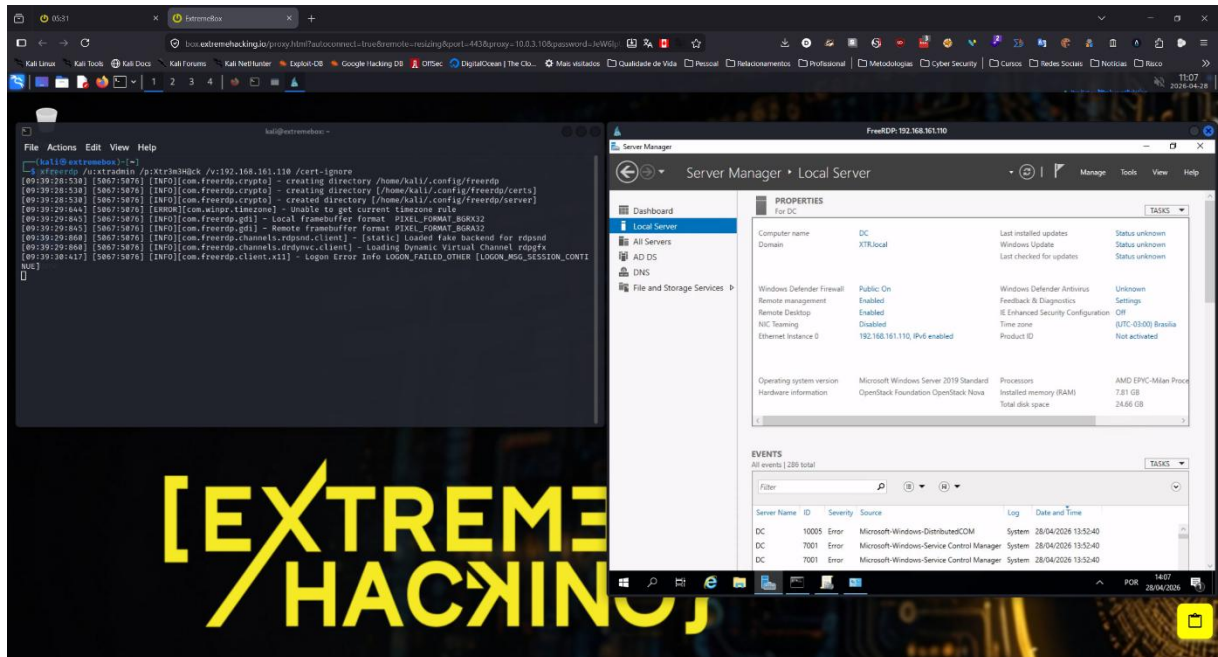
Controle ISO 27001:2022: A.5.32 – Direitos de Propriedade Intelectual

Requisito avaliado: Licenciamento e conformidade de software de sistema.

Evidência coletada: O sistema operacional Windows Server 2019 do DC consta como “Not activated”.

Arquivo de evidência:

Figura 9. ID DO ACHADO: AUD-008



Fonte: Captura de tela realizada pelo Auditor (2026)

Hash SHA-256: SHA256 hash de 2026-04-28 11_04_47-ExtremeBox -Mozilla Firefox.png:
d52026993cb56fd4676ef6915762a9085cd567d31e92765ca1edb4d136d19268

Data/hora da coleta: 27/04/2026 - 11:07 - UTC-3

Coletado por: Odail Della Niesi Junior

Impacto: Risco jurídico e potencial interrupção de serviços ou acesso a atualizações críticas por falta de ativação.

Recomendação: Regularizar o licenciamento junto ao fornecedor.

Prazo: NC-BAIXA: 30 dias.

ID DO ACHADO: AUD-009

Controle: PCI DSS v4.0.1: 10.7 - ISO 27001:2022: A.8.10 -Registro de Eventos e Retenção de Logs

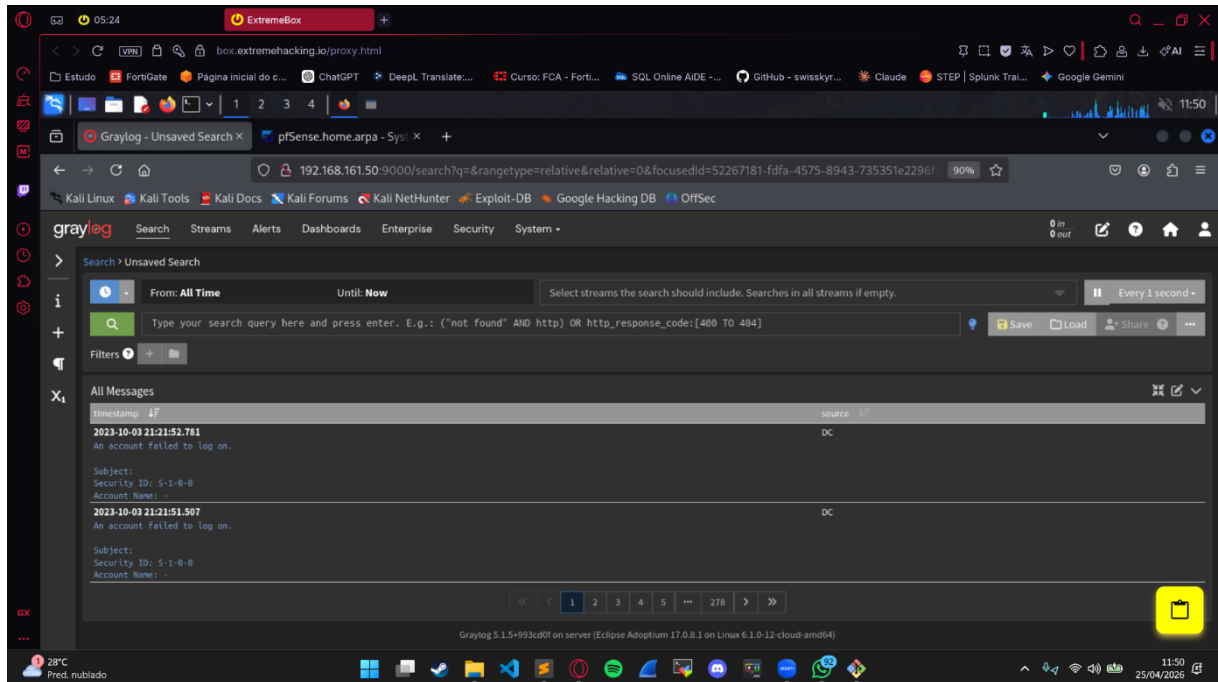
Classificação: NÃO CONFORME CRÍTICA

Requisito avaliado: Retenção, integridade e continuidade dos logs de auditoria para fins de rastreabilidade e resposta a incidentes.

Evidência coletada: Durante a análise técnica na ferramenta Graylog, identificou-se que o sistema não recebe registros de logs de nenhum ativo de rede ou servidor desde o ano de 2023. Esta lacuna de aproximadamente 3 anos viola diretamente a exigência de manutenção de histórico para auditorias forenses.

Arquivo de evidência:

Figura 10. ID DO ACHADO: AUD-009



Fonte: Captura de tela realizada pelo Auditor (2026)

Hash SHA-256:

C9C953C753B5EC8A9D1490C88324E2F511579A438507AE76396A3C6B707545B0

Data/hora da coleta: 25/04/2026 -11:50 -UTC-3

Coletado por: Pablo Gomes Sales da Silva

Impacto: Inviabilização total de auditorias forenses e investigações de incidentes ocorridos nos últimos 3 anos. A ausência de logs impede a detecção de invasões em tempo real, gera a perda imediata da certificação PCI DSS (que exige 1 ano de retenção) e deixa a empresa vulnerável a ataques indetectáveis.

Recomendação: Identificar a causa da interrupção, reestabelecer o envio de logs de todos os ativos críticos para o Graylog e implementar alertas de “Heartbeat” que notifiquem a equipe de segurança caso o Graylog deixe de receber logs por mais de 5 minutos.

Prazo: NC-CRÍTICA: 7 dias.

ID DO ACHADO: AUD-010

Controle: Política de Monitoramento: A.5.b -Auditoria de Sistemas - PCI DSS v4.0.1: 6.3.3 - Gestão de Vulnerabilidades - ISO 27001:2022: A.8.8 -Gestão de Vulnerabilidades Técnicas

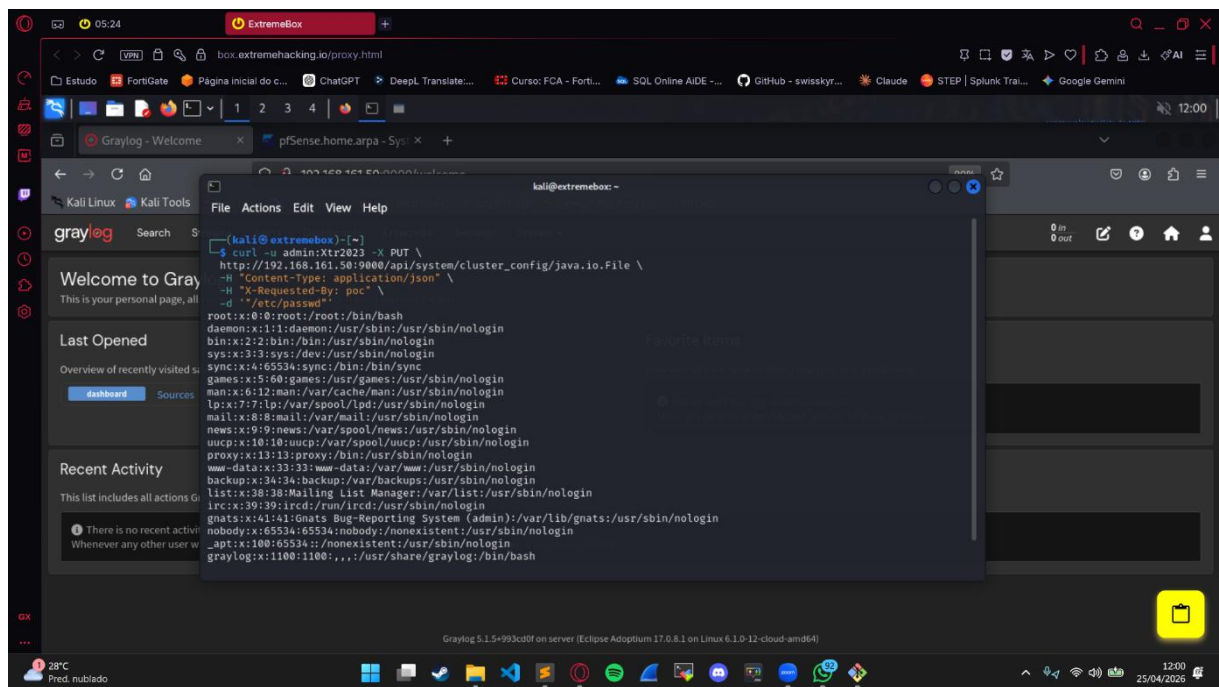
Classificação: NÃO CONFORME CRÍTICA

Requisito avaliado: Identificação e correção de vulnerabilidades potenciais e manutenção de patches de segurança atualizados.

Evidência coletada: O servidor Graylog (192.168.161.50) opera na versão 5.1.5, vulnerável à CVE-2024-24824. Através de testes técnicos via curl, confirmou-se que a aplicação permite a instanciação de classes Java arbitrárias. Foi possível realizar a leitura de arquivos sensíveis do sistema operacional (ex: /etc/passwd), evidenciando uma falha grave de sanitização de entradas.

Arquivo de evidência:

Figura 11. ID DO ACHADO: AUD-010



Fonte: Captura de tela realizada pelo Auditor (2026)

Hash SHA-256:

6D97178DC36CB3C36EB41696085081E77357AEEBAD434D1DBD624BF52BEA914B

Data/hora da coleta: 25/04/2026 -12:00 -UTC-3

Coletado por: Pablo Gomes Sales da Silva

Impacto: Risco altíssimo de exposição de dados sensíveis e credenciais armazenadas no servidor. A vulnerabilidade permite que um atacante obtenha informações estruturais do sistema operacional, podendo evoluir para uma Execução Remota de Código (RCE) e comprometimento total do ambiente de monitoramento.

Recomendação: Atualizar o Graylog para versão em que a falha foi corrigida e restringir as permissões do usuário que executa o serviço Graylog no Linux para que ele não tenha acesso de leitura a arquivos sensíveis do sistema.

Prazo: NC-CRÍTICA: 7 dias.

ID DO ACHADO: AUD-011

Controle: ISO 27001:2022: A.5.9, A.8.15 e A.8.16 -Logging e Monitoramento - PCI DSS v4.0.1: 10.2.1.1, 12.5.1 Identificação de componentes do sistema - Política de Monitoramento: 5.b.

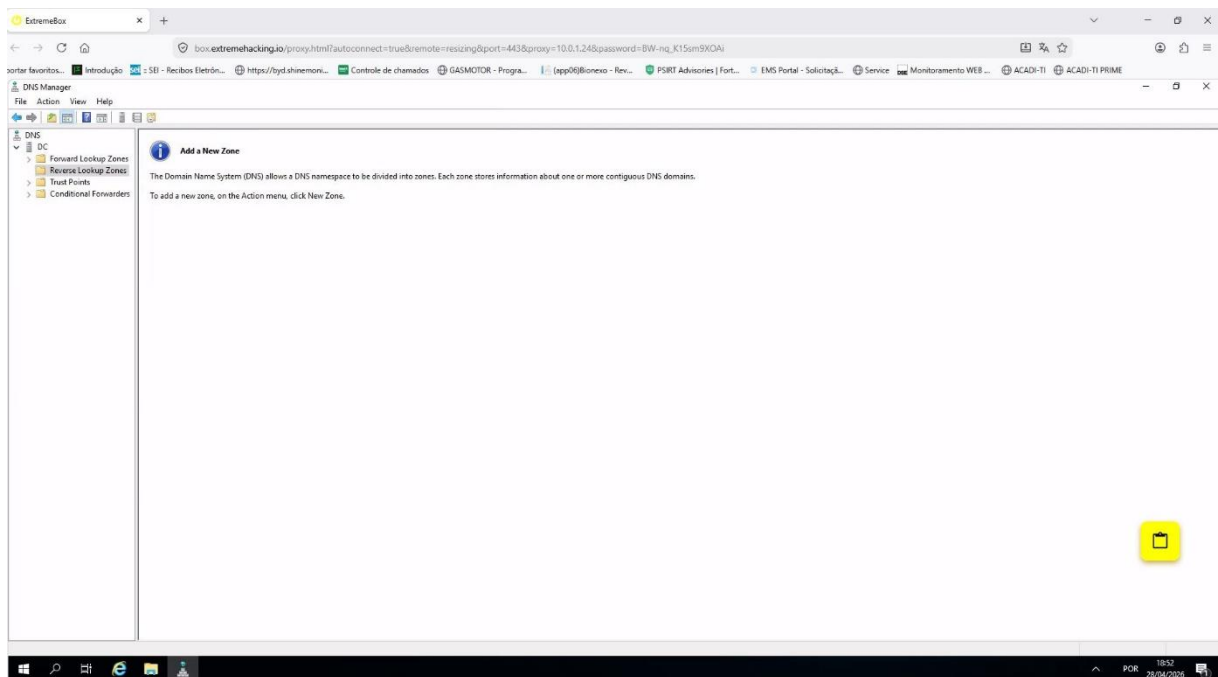
Classificação: NÃO CONFORME ALTA

Requisito avaliado: Monitoramento e Revisão.

Evidência coletada: A ausência de uma zona de DNS Reverso (rDNS), que mapeia endereços IP para nomes de domínio (registros PTR), é uma falha de configuração que impacta diretamente a confiabilidade e a segurança da rede. Sem DNS reverso, ferramentas de rede essenciais perdem clareza.

Arquivo de evidência:

Figura 12. ID DO ACHADO: AUD-011



Fonte: Captura de tela realizada pelo Auditor (2026)

Hash SHA-256:

C11D64FA18F3992D495BBB97DDE08D0B9479E33CD51F93BF475089F7B7CAD78D

Data/hora da coleta: 28/04/2026 -18:52 -UTC-3

Coletado por: Cristiano da Cruz Carvalho

Impacto: Facilita o *Shadow IT*. Atacantes podem subir máquinas e, como elas não têm nomes associados, elas passam despercebidas em varreduras superficiais baseadas em nomes de host. Dificulta a correlação de logs. Logs de firewalls e IDSs tornam-se muito mais difíceis de analisar sem a resolução de nomes.

Recomendação: Certifique-se de que as subnets dos servidores (Core) e das estações tenham zonas reversas integradas ao Active Directory. Ative o scavenging de registros antigos. Registros PTR obsoletos são tão perigosos quanto a falta deles, pois levam você a acreditar que um IP pertence a uma máquina que já foi desativada.

Prazo: NC-ALTA: 15 dias.

ID DO ACHADO: AUD-012

Controle: ISO 27001:2022: A.8.7, A.8.15 e A.8.25 -Logging e Gestão de Vulnerabilidades - PCI DSS v4.0.1: 5.2.1, 5.3.1 -Proteção de componentes do sistema - Política de Monitoramento: 5.b.

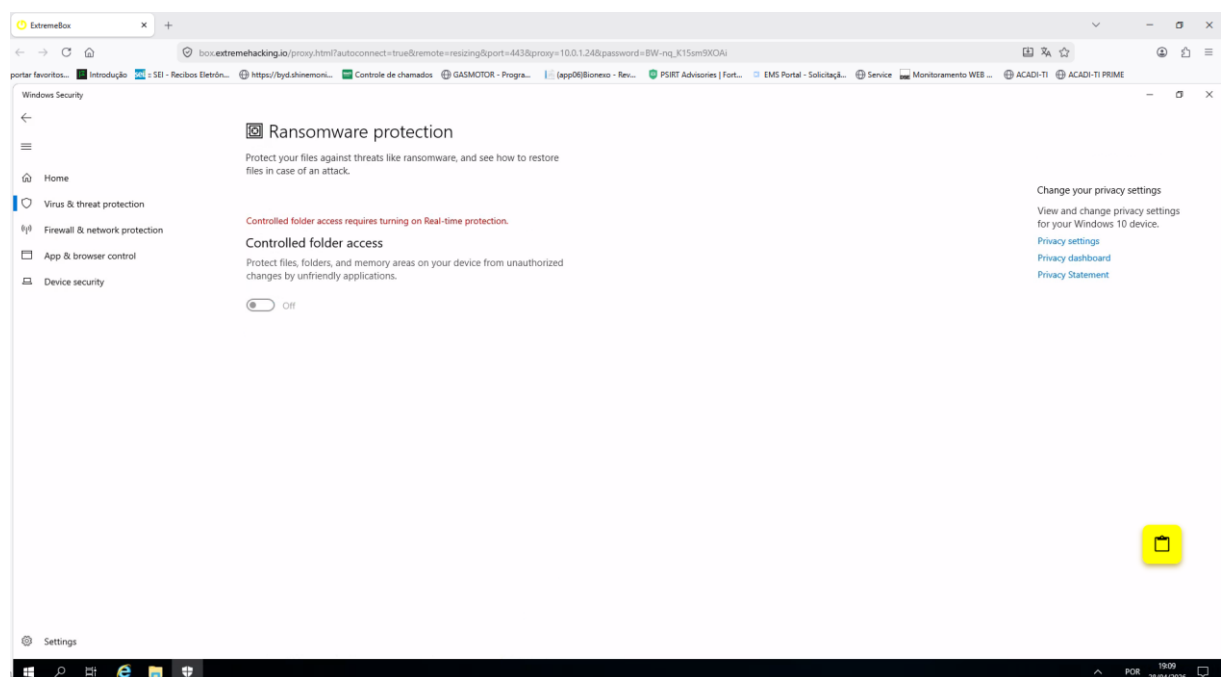
Classificação: NÃO CONFORME CRÍTICA

Requisito avaliado: Monitoramento e Revisão.

Evidência coletada: O Windows Defender Virus & Threat Protection está com o Real-time Protection e o Ransomware Protection desativado.

Arquivo de evidência:

Figura 13. ID DO ACHADO: AUD-012



Fonte: Captura de tela realizada pelo Auditor (2026)

Hash SHA-256:

D3CA8F8929DBB6B10C77A9D279A7F96B2EE8734973E194C6670A16AEBB0356D8

Data/hora da coleta: 28/04/2026 -19:09 -UTC-3

Coletado por: Cristiano da Cruz Carvalho

Impacto: Com o **Real-time Protection** desativado, o sistema não está verificando arquivos no momento em que são abertos ou executados. Já a falta do **Ransomware Protection** (geralmente o *Controlled Folder Access*) deixa seus volumes de dados e backups locais vulneráveis a criptografia não autorizada.

Recomendação: Forçar Reativação via GPO. Não dependa da ativação manual. Configure uma Política de Grupo para garantir que o Defender esteja sempre ativo e que o usuário local não possa desativá-lo.

Prazo: NC-CRÍTICA: 7 dias.

ID DO ACHADO: AUD-013

Controle: ISO 27001:2022: A.5.35, A.8.8 e A.8.16 -Monitoramento e Gestão de Vulnerabilidades - PCI DSS v4.0.1: 11.3.1 e 10.4.11 -Monitoramento de Vulnerabilidades de Logs - Política de Monitoramento: 5.b.

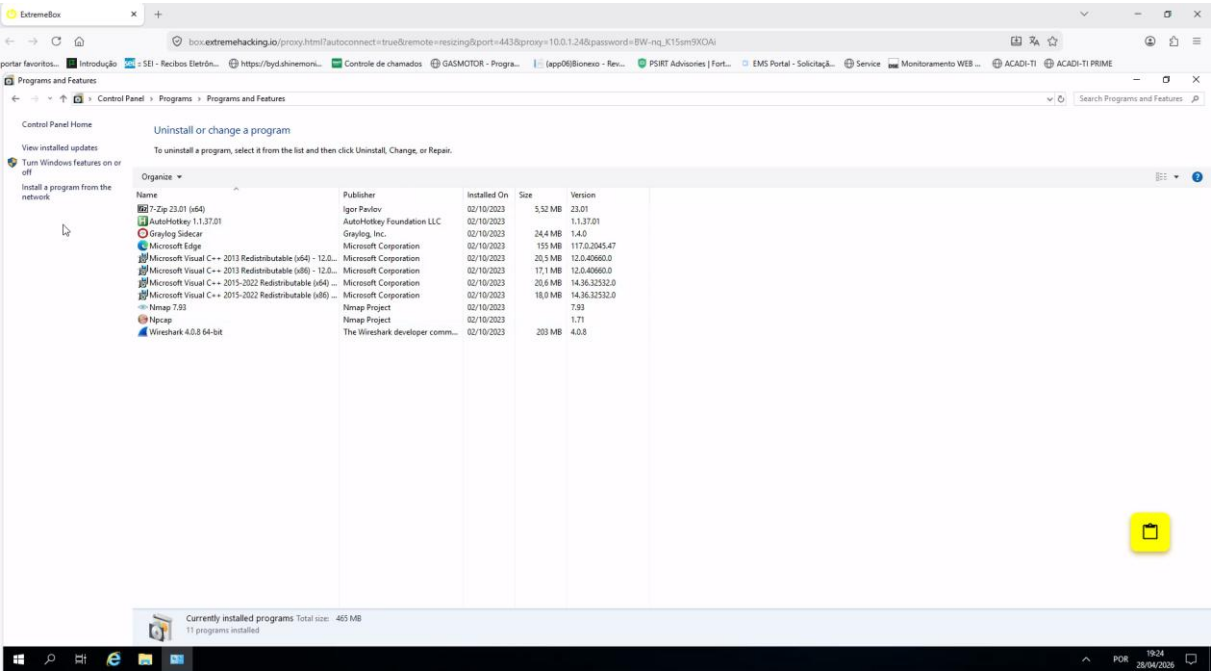
Classificação: NÃO CONFORME ALTA

Requisito avaliado: Monitoramento e Revisão.

Evidência coletada: Aplicativos instalados com versões ultrapassadas e vulneráveis.

Arquivo de evidência:

Figura 14. ID DO ACHADO: AUD-013



Fonte: Captura de tela realizada pelo Auditor (2026)

Hash SHA-256:

4FC8E54D28D9441EF12A016BEFF7B0135137E8A5883C245F79734227A80F2A96

Data/hora da coleta: 28/04/2026 -19:24 -UTC-3

Coletado por: Cristiano da Cruz Carvalho

Impacto: Softwares vulneráveis são portas de entrada para alterar binários do sistema. O monitoramento de integridade deve detectar se uma CVE foi usada para trocar um .exe legítimo por um trojan.

Recomendação: Avalie Implementar um ciclo mensal de Patch Management, objetivando fechar brechas (CVEs) em navegadores, plugins e aplicativos que são a porta de entrada para invasões.

Prazo: NC-ALTA: 15 dias.

ID DO ACHADO: AUD-014

Controle: ISO 27001:2022: A.5.18 - Direitos de Acesso

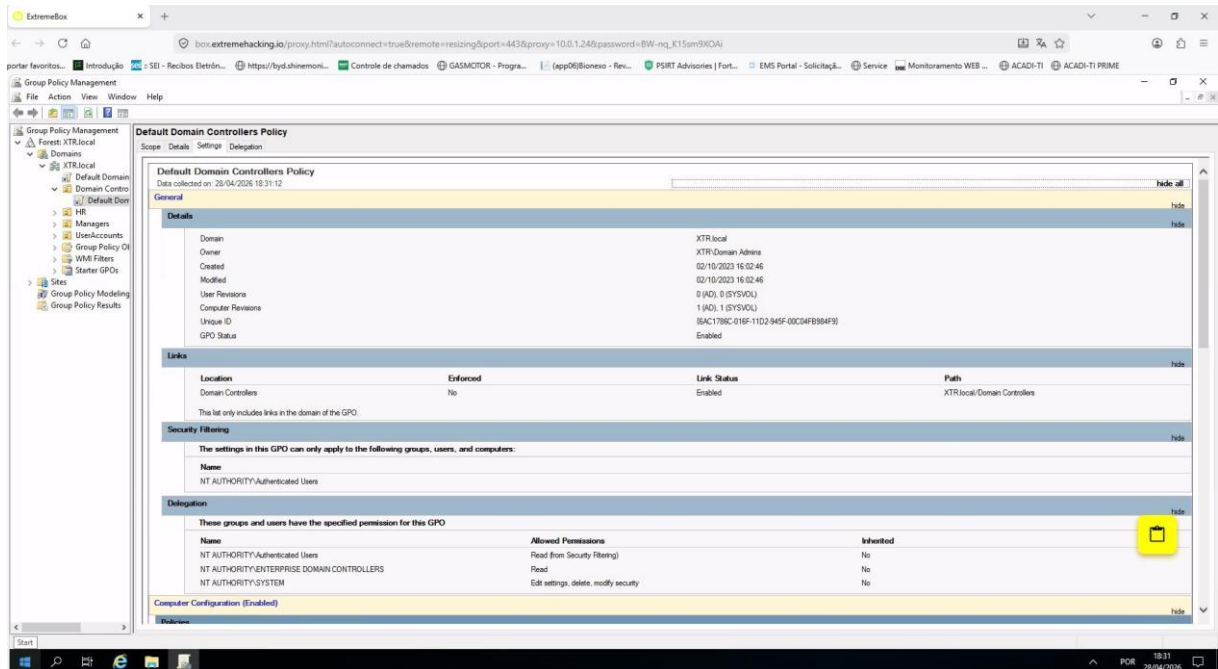
Classificação: NÃO CONFORME ALTA

Requisito avaliado: Controle de concessão de privilégios e aderência ao princípio do menor privilégio.

Evidência coletada: A Default Domain Controllers Policy permite que qualquer usuário autenticado ingresse máquinas no domínio, configurando privilégio excessivo e inadequado para usuários comuns.

Arquivo de evidência:

Figura 15. ID DO ACHADO: AUD-014



Fonte: Captura de tela realizada pelo Auditor (2026)

Hash SHA-256:

9AFCA8C26482C0BB60D64C5006964E1BD94598024C01137F38D1700AA05627FA

Data/hora da coleta: 28/04/2026 -18:31 -UTC-3

Coletado por: Cristiano da Cruz Carvalho

Impacto: Possibilita a inclusão não controlada de dispositivos no domínio, comprometendo a integridade do ambiente, facilitando ataques de movimentação lateral e violando o princípio do menor privilégio.

Recomendação: Restringir a permissão de ingresso de máquinas no domínio apenas a usuários autorizados (administradores), ajustando as políticas de grupo (GPO) conforme o princípio do menor privilégio.

Prazo: NC-ALTA: 15 dias.

ID DO ACHADO: AUD-015

Controle: ISO 27001:2022: A.8.2 -Direitos de Acesso Privilegiado - PCI DSS v4.0.1: 2.2.2 - Política de Monitoramento: 5.c.

Classificação: NÃO CONFORME ALTA

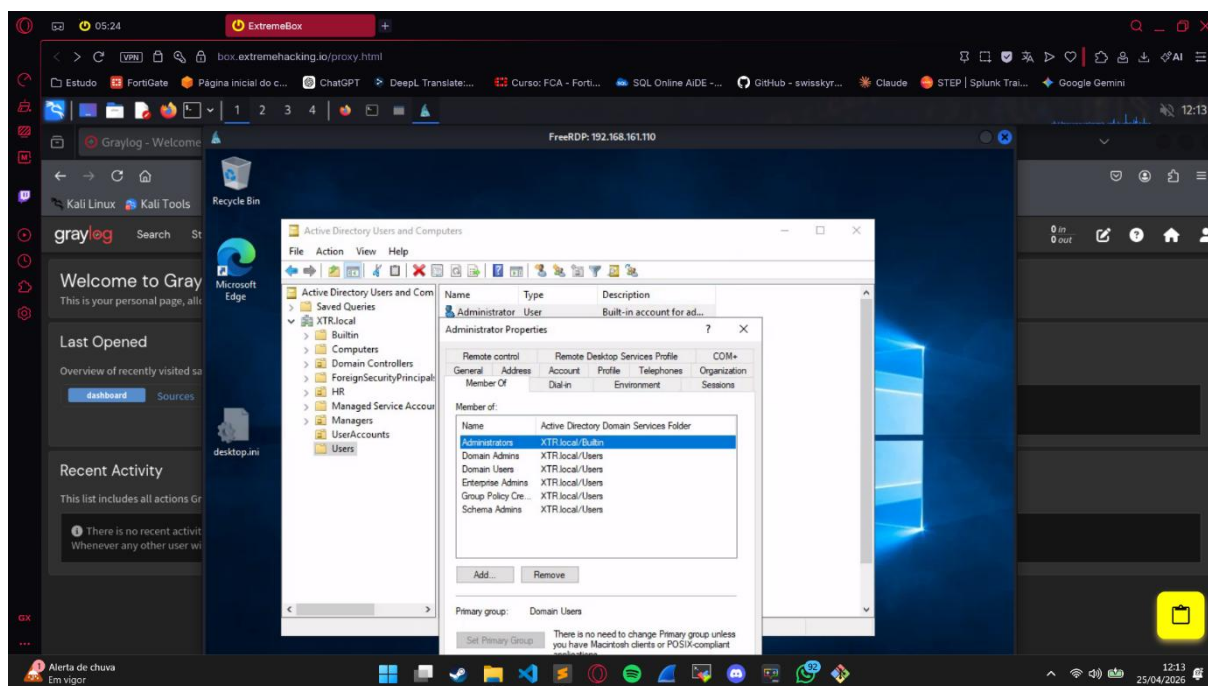
Requisito avaliado: Gerenciamento de contas padrão e garantia de identificação inequívoca de usuários com privilégios administrativos

Evidência coletada: Durante a auditoria nas configurações do Active Directory e nas Políticas de Segurança Local, confirmou-se que a conta de sistema padrão “administrator” está habilitada

e ativa. Não há evidências de que esta conta tenha sido renomeada ou que seu uso seja restrito a situações de emergência documentadas.

Arquivo de evidência:

Figura 16. ID DO ACHADO: AUD-015



Fonte: Captura de tela realizada pelo Auditor (2026)

Hash SHA-256:

A0DA4CB373365771B3A57EBF12E470590EE15B240717117C202AF8D93C3944C0

Data/hora da coleta: 25/04/2026 -12:13 -UTC-3

Coletado por: Pablo Gomes Sales da Silva

Impacto: Perda total da Rastreabilidade (Accountability). Ações realizadas por esta conta não podem ser atribuídas a um indivíduo específico, invalidando logs de auditoria em caso de incidentes. Além disso, facilita ataques de força bruta, uma vez que o nome de usuário é universalmente conhecido.

Recomendação: Garantir que todos os administradores utilizem contas individuais e identificáveis e desativar a conta “administrator” após a confirmação de que as novas contas nominais possuem os privilégios necessários.

Prazo: NC-ALTA: 15 dias.

ID DO ACHADO: AUD-016

Controle: ISO 27001:2022: A.8.10 -Logging (Registros) - PCI DSS v4.0.1: 10.2.1 - Política de Monitoramento: 5.a.

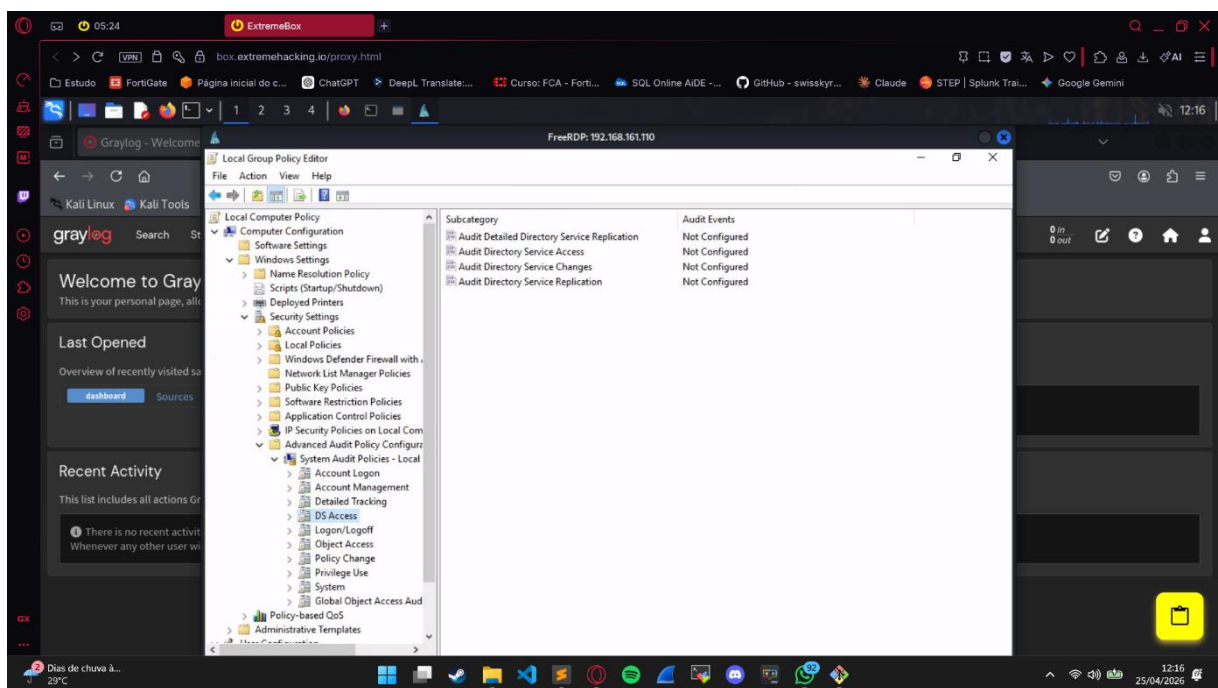
Classificação: NÃO CONFORME CRÍTICA

Requisito avaliado: Configuração mandatória de políticas de auditoria avançada no nível do sistema operacional para garantir a geração e captura de eventos de segurança críticos.

Evidência coletada: Durante a inspeção no Editor de Gerenciamento de Grupo (GPO), especificamente na seção de “Advanced Audit Policy Configuration”, identificou-se que subcategorias essenciais como “DS Access” (Acesso ao Serviço de Diretório) e “Logon/Logoff” estão definidas como “Not Configured”.

Arquivo de evidência:

Figura 17. ID DO ACHADO: AUD-016



Fonte: Captura de tela realizada pelo Auditor (2026)

Hash SHA-256:

DDBC055E24F2FBF5A5188FFCCEC8AD1F88785B5E37FE185D4DD3517104BDA3DB

Data/hora da coleta: 25/04/2026 -12:17 -UTC-3

Coletado por: Pablo Gomes Sales da Silva

Impacto: Cegueira operacional completa. Como o sistema operacional não gera os eventos, o Graylog não recebe dados, tornando o investimento na ferramenta de monitoramento inútil para detecção de ameaças. Isso impede a identificação de alterações não autorizadas no Active Directory e viola o Requisito 10 do PCI DSS, que exige trilhas de auditoria para todas as ações administrativas.

Recomendação: Configurar as Políticas de Auditoria Avançada para registrar “Sucesso” e “Falha” em categorias críticas (Acesso ao AD, Gerenciamento de Contas e Logons), aplicar um

template de segurança (como o do CIS Benchmarks) para garantir que todos os servidores da rede gerem logs padronizados e após a ativação, realizar um teste de alteração de objeto no AD e validar se o log aparece no event viewer e no dashboard do Graylog em tempo real.

Prazo: NC-ALTA: 07 dias.

8. CADEIA DE CUSTÓDIA - Auditoria VirtuaTech (RAI 001/2026)

Visando o atendimento aos requisitos de integridade e custódia sobre as evidências colhidas no ambiente VirtuaTech, a tabela abaixo sumariza o controle dos achados técnicos. Os **Termos de Cadeia de Custódia** correspondentes, devidamente preenchidos, foram incluídos como anexos deste relatório.

Tabela 1. Controle dos achados técnicos

ID Evidência	Achado	Tipo	Nome do Arquivo / Descrição	Data/Hora (2026)	Coletado por	Hash SHA-256	Status
EVI-001	AUD-001	PNG	Graylog - Sources.png	28/04 - 09:50	Odail Junior	b0e4d924ce00a21e7afc8dbc2d47b5796c6f7787bacac43ef596c03606fbde78	Original
EVI-002	AUD-002	PNG	pfSense - Dashboard.png	28/04 - 10:00	Odail Junior	dffe7d009cd0a158712a5e6f6d8f636868637d3bff0c4f0299408d38c78690b4	Original
EVI-003	AUD-003	PNG	pfSense - WAN Rules (RDP).png	28/04 - 10:03	Odail Junior	f723f8e797c38a1b5ed5c0d46b7629e203e4479a019715383135578a2c48ba10	Original
EVI-004	AUD-004	PNG	pfSense - Default Password Warning.png	28/04 - 10:07	Odail Junior	d90749bae3a9f16234843c6431614162df6d7d1acb688efe96e15d83c323cbe0	Original
EVI-005	AUD-005	PNG	AD - Password Policy GPO.png	28/04 - 10:13	Odail Junior	a2b29e9e1d19aa761dd4c0f8a7779fd99fe0989ffaf9537c81d3c113c082acca	Original

EVI-006	AUD-006	PNG	DC - Installed Hacking Tools.png	28/04 - 11:01	Odail Junior	8ae74f37fe26803a3807ee90c5782f73f1cc3ad63266bf0087f5b1c9138dc6c0	Original
EVI-007	AUD-007	PNG	Policy - Invalid Revision Date.png	28/04 - 11:02	Odail Junior	1a39f7b7d0e31c24fe3273e3db304618c221836845a91acb63d4aa533fee4ff4	Original
EVI-008	AUD-008	PNG	DC - Windows Not Activated.png	27/04 - 11:07	Odail Junior	d52026993cb56fd4676ef6915762a9085cd567d31e92765ca1edb4d136d19268	Original
EVI-009	AUD-009	PNG	Graylog - Log Inactivity Gap (2023).png	25/04 - 11:50	Pablo Silva	C9C953C753B5EC8A9D1490C88324E2F511579A438507AE76396A3C6B707545B0	Original
EVI-010	AUD-010	PNG	Graylog - CVE-2024-24824 Exploitation.png	25/04 - 12:00	Pablo Silva	6D97178DC36CB3C36EB41696085081E77357AEEBAD434D1DBD624BF52BEA914B	Original
EVI-011	AUD-011	JPG	AD - DNS Reverso não configurado.jpg	28/04 – 18:52	Cristiano Carvalho	C11D64FA18F3992D495BBB97DDE08D0B9479E33CD51F93BF475089F7B7CAD78D	Original
EVI-012	AUD-012	JPG	AD - Ransomware Protection Desabilitado.jpg	28/04 – 19:09	Cristiano Carvalho	D3CA8F8929DBB6B10C77A9D279A7F96B2EE8734973E194C6670A16AEBB0356D8	Original

EVI-013	AUD-013	JPG	AD - Aplicativos Vulneráveis.jpg	28/04 – 19:24	Cristiano Carvalho	4FC8E54D28D944 1EF12A016BEFF7 B0135137E8A588 3C245F79734227A 80F2A96	Original
EVI-014	AUD-014	JPG	AD - Default Domain Controllers Policy.jpg	28/04 – 18:31	Cristiano Carvalho	9AFCA8C26482C 0BB60D64C50069 64E1BD94598024 C01137F38D1700 AA05627FA	Original
EVI-015	AUD-015	PNG	AD – User Default.png	25/04 – 12:13	Pablo Silva	A0DA4CB373365 771B3A57EBF12E 470590EE15B2407 17117C202AF8D9 3C3944C0	
EVI-016	AUD-016	PNG	AD – Policy Audit.png	25/04 – 12:16	Pablo Silva	DDBC055E24F2F BF5A5188FFCCE C8AD1F88785B5E 37FE185D4DD351 7104BDA3DB	

Fonte: Elaborado pelos Auditores (2026)

Notas de Auditoria:

- **Responsabilidade:** A coleta foi dividida entre os auditores Odail Della Niesi Junior, Pablo Gomes Sales da Silva e Cristiano da Cruz Carvalho conforme o cronograma das fases 2 e 3.
- **Integridade:** Todos os arquivos possuem hash SHA-256 verificados para garantir que as evidências não foram alteradas após a coleta no laboratório.

9. ANÁLISE DE RISCOS

Baseado na Matriz de Riscos (Probabilidade x Impacto) adaptada dos modelos de auditoria interna, os riscos foram classificados considerando uma escala de 1 a 5 para probabilidade e impacto.

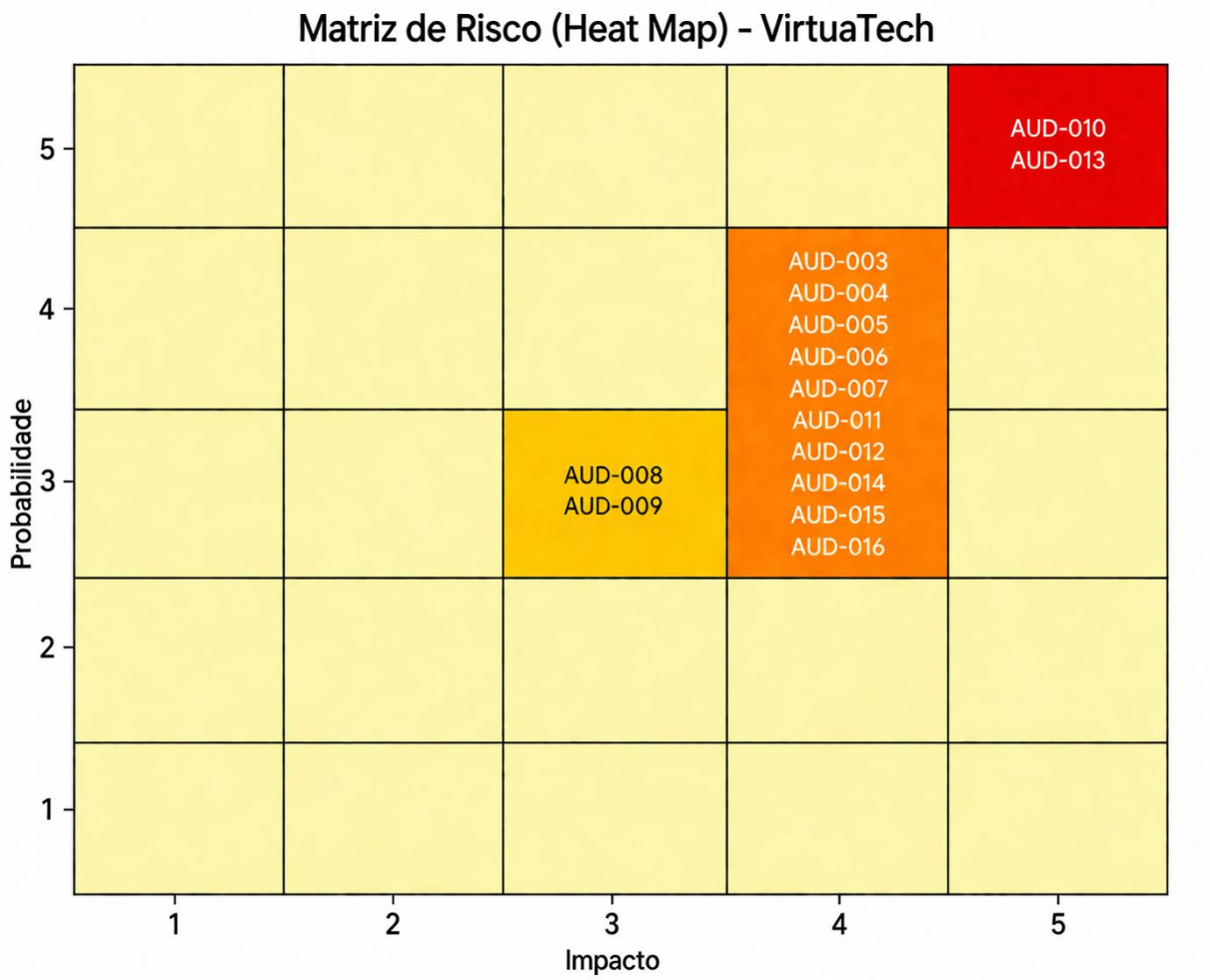
Tabela 2. Matriz de riscos

ID do Achado	Evento de Risco	Probabilidade (P)	Impacto (I)	Risco (P×I)	Classificação
AUD-010	Graylog com versão vulnerável	5	5	25	Crítico
AUD-003	Acesso Externo Direto via RDP ao DC	5	5	25	Crítico
AUD-012	Ransomware Protection não habilitado	5	5	25	Crítico
AUD-016	Policy DS Access não configurada	5	5	25	Crítico
AUD-003	Acesso a porta 3389 (RDP) liberado para qualquer host da internet	4	4	16	Alto
AUD-004	Uso de credenciais padrão no PFSense	4	4	16	Alto
AUD-005	Possibilidade de ataque de força bruta – Policy Default Domain	4	4	16	Alto
AUD-009	SIEM não recebe logs	4	4	16	Alto
AUD-006	Ferramentas hacking instaladas no DC	4	4	16	Alto
AUD-011	Senha administrativa do Graylog sem complexidade	4	4	16	Alto
AUD-011	DNS Reverso não conforme	4	4	16	Alto
AUD-013	Aplicativos vulneráveis no DC	4	4	16	Alto
AUD-014	Política Default Domain Controllers	4	4	16	Alto
AUD-015	DC com usuário Administrator ativado	4	4	16	Alto
AUD-008	Política de monitoramento sem revisão	3	3	09	Baixo

AUD-008	Sistema Operacional não licenciado	3	3	09	Baixo
---------	------------------------------------	---	---	----	-------

Fonte: Elaborado pelos Auditores (2026)

Figura 18. Gráfico Matriz de Risco



9.1. Interpretação da Matriz de Risco (Heat Map)

A visualização acima consolida o cenário de exposição da VirtuaTech ao cruzar a Probabilidade de ocorrência de uma ameaça com o Impacto potencial nos ativos de informação. A distribuição dos achados revela um perfil de risco acentuado, conforme detalhado abaixo:

- **Quadrante Crítico (Vermelho):** Representa vulnerabilidades com alta probabilidade de exploração e impacto severo à continuidade do negócio. Os itens AUD-010, AUD-013 situam-se nesta zona.
- **Quadrante de Alto Risco (Laranja):** Concentra a maior densidade de achados, São eles: AUD-003, AUD-004, AUD-005, AUD-006, AUD-007, AUD-011, AUD-012,

AUD-014, AUD-015, AUD-016. Embora o impacto possa ser ligeiramente menor ou a probabilidade mitigada por algum controle periférico, a combinação desses itens indica uma fragilidade sistêmica e no controle de perímetro. A persistência destes riscos fragiliza a postura de segurança a curto prazo.

- **Quadrante de Médio/Baixo Risco (Amarelo):** Itens como AUD-008 e AUD-009 apresentam menor probabilidade de exploração imediata, mas não devem ser ignorados, pois servem frequentemente como vetores secundários em ataques multiestágio.

Conclusão da Análise: A concentração de ativos no quadrante superior direito (Alta Probabilidade vs. Alto Impacto) indica que a VirtuaTech opera atualmente com um Risco Residual inaceitável perante as melhores práticas da ISO/IEC 27001. Ações de remediação imediatas são necessárias para deslocar esses indicadores para as zonas de menor risco (quadrantes inferiores esquerdos).

10. CONCLUSÃO

A auditoria realizada na infraestrutura da VirtuaTech, avaliou os controles de segurança da informação em ativos críticos da organização, como: o Firewall pfSense, o Controlador de Domínio (Active Directory) e o sistema de monitoramento centralizado (Graylog), tendo como referência os requisitos da norma ISO/IEC 27001:2022.

Os trabalhos identificaram diversas vulnerabilidades, classificadas entre os níveis Crítico, Alto e Médio, configurando um risco residual inaceitável para a continuidade do negócio. Entre as falhas mais graves estão: uso de credenciais padrão no Firewall pfSense; exposição direta do protocolo RDP do Controlador de Domínio à rede pública (WAN); ausência de patches de segurança nos sistemas operacionais; tráfego administrativo não criptografado (HTTP); e inoperância do sistema SIEM para geração de alertas pró-ativos, agravada pela interrupção da coleta de logs desde 2023.

Conclui-se que o processo de monitoramento de redes e sistemas da VirtuaTech encontra-se em estado crítico de maturidade, não sendo efetivo para garantir a integridade, confidencialidade e disponibilidade dos ativos de informação. A implementação imediata das ações de remediação previstas no Plano de Priorização (Seção 15), com especial atenção às correções de perímetro e à restauração do pipeline de logs, é mandatória para mitigar o risco residual identificado e iniciar o alinhamento com os requisitos da ISO/IEC 27001:2022.

11. RECOMENDAÇÕES GERAIS

- **Técnicas:** Configurar isolamento de interfaces de gerenciamento (OOB Management), aplicar regras “Deny-All” por padrão na WAN do firewall, forçar uso de TLS 1.2+ em aplicações web (Graylog e pfSense) e restabelecer o *pipeline* de ingestão de logs do SIEM.
- **Processuais:** Instituir a revisão periódica de controles de acesso e contas privilegiadas no Active Directory. Criar procedimentos documentados para ativação de alertas e resposta a incidentes baseados nos eventos coletados.
- **Estratégicas:** Formalizar políticas de monitoramento rigorosas segundo a norma ISO 27001. A diretoria deve promover um programa contínuo de avaliação e gestão de vulnerabilidades para evitar degradações sistêmicas do ambiente.

12. ARQUITETURA DE SEGURANÇA RECOMENDADA

A nova arquitetura foca na segregação de funções e na proteção de identidades, eliminando a exposição direta de ativos críticos à rede pública.

- **Perímetro Blindado (Firewall pfSense):** Substituição do acesso RDP/ICMP direto por um **Túnel VPN (OpenVPN/IPsec)** com autenticação de dois fatores (MFA).
 - Implementação de **IPS/IDS (Suricata/Snort)** para detecção de intrusões em tempo real.
- **Segregação de Redes (VLANs):**
 - **VLAN de Gerência:** Isolamento das interfaces web do pfSense e Graylog, acessíveis apenas via VPN ou estações administrativas autorizadas.
 - **VLAN de Servidores:** Isolamento do Controlador de Domínio, sem comunicação direta com a WAN.
- **Comunicação Criptografada:**
 - Implementação de **HTTPS (Porta 443)** com certificados TLS em todos os consoles de gerenciamento.
- **Monitoramento Centralizado e Inteligente (Graylog):**
 - Configuração de correlação de eventos para alertar automaticamente tentativas de força bruta e mudanças em grupos administrativos do AD.

13. QUADRO COMPARATIVO: ATUAL VS. DESEJADO

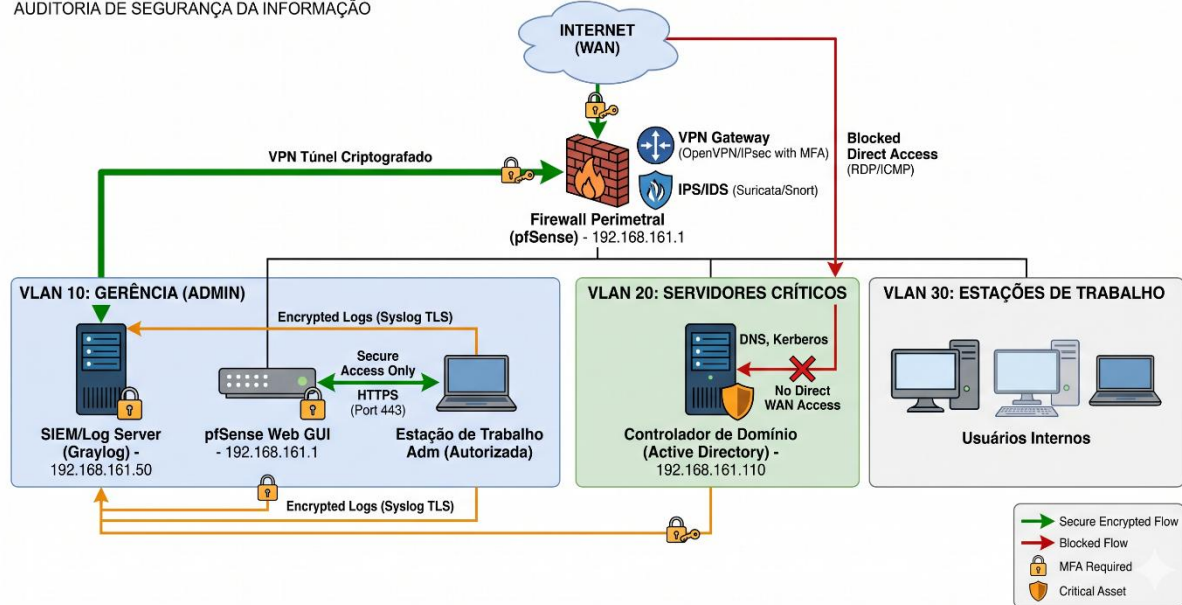
Tabela 3. Quadro comparativo

Componente	Estado Atual (As-Is)	Estado Desejado (To-Be)
Acesso Administrativo	Protocolo HTTP (Inseguro)	Protocolo HTTPS (Criptografado)
Acesso Externo	RDP exposto na WAN	VPN com MFA
Identidade	Senhas Padrão / Usuários Genéricos	Senhas Fortes / Contas Individuais (RBAC)
Visibilidade	Logs passivos (sem alertas)	Alertas pró-ativos de segurança (SOC)

Fonte: Elaborado pelos Auditores (2026)

Figura 19. Topologia de Rede recomendada

TOPOLOGIA IDA - TOPOLOGIA DE REDE 'TO-BE' RECOMENDADA - VIRTUATECH
AUDITORIA DE SEGURANÇA DA INFORMAÇÃO



Fonte: Elaborado pelos Auditores (2026)

A topologia apresentada na Figura 19 materializa a estratégia de remediação dos achados críticos deste relatório. A nova arquitetura baseia-se no princípio de Defesa em Profundidade (Defense in Depth), estruturando-se nos seguintes pilares:

- **Extinção da Superfície de Ataque Direta:** A principal mudança é a remoção da exposição direta de protocolos como RDP e ICMP na interface WAN. O acesso externo passa a ser mediado obrigatoriamente por um Gateway VPN com MFA (Autenticação Multifator), garantindo que apenas usuários autenticados e criptografados acessem a rede interna.
- **Segregação por VLANs (Virtual Local Area Networks):** Diferente do estado atual, onde os ativos residem em um barramento plano, a nova estrutura segrega os ativos por criticidade:
 - **VLAN de Gerência:** Protege as interfaces administrativas (pfSense/Graylog).
 - **VLAN de Servidores:** Isola o Controlador de Domínio de comunicações desnecessárias.
- **Segurança de Tráfego Administrativo:** A figura ilustra o uso de HTTPS e Syslog sobre TLS. Isso endereça o risco de interceptação de credenciais (Sniffing/MitM) identificado durante a fase de execução da auditoria.

- **Monitoramento Ativo (SOC):** O fluxo de logs é agora centralizado e alertável, transformando o Graylog de um repositório passivo em uma ferramenta de resposta a incidentes em tempo real.

14. MATRIZ DE REQUISITOS

Abaixo, o acompanhamento dos requisitos testados contra as políticas de monitoramento e padrões exigidos:

Tabela 4. Requisitos

Controle avaliado	Status	Evidência	Observação	Recomendação
Continuidade e Disponibilidade	Conforme	Servidores (AD, Graylog, pfSense) operacionais e acessíveis.	Os ativos de rede puderam ser acessados sem interrupções durante a auditoria.	Manter as políticas de alta disponibilidade operantes.
Registro e Centralização de Eventos	Conforme	Logs e eventos centralizados no Graylog.	O Graylog está configurado para coletar e centralizar logs do AD e do Firewall corretamente.	Garantir capacidade de disco (<i>storage</i>) para retenção a longo prazo.
Análise Regular de Logs	Não Conforme	Último log registrado em 2023.	O sistema de ingestão de dados está inativo ou configurado incorretamente. O Graylog também expõe as informações para acesso público.	Corrigir o sistema de ingestão, aplicar controle de acesso rígido e auditar logs regularmente.
Revisão de Acessos	Não Conforme	Firewall pfSense usando senhas de fábrica (admin/pfsense).	Além do firewall, foram expostas senhas em documentos técnicos e detectou-se acesso de administrador para usuário comum (acacio.flores).	Mudar senhas padrão, implementar cofre de senhas e auditar privilégios de todos os usuários.
Integridade dos Dados	Não Conforme	Uso do parâmetro /cert-ignore via xfreerdp.	Uso de HTTP para gerência (portas 80 e 9000). Permite ataques MitM comprometendo a sessão.	Implementar forçadamente certificados válidos e trafegar gerência exclusivamente via HTTPS.
Monitoramento Pró-Ativo	Não Conforme	Graylog sem alertas para força bruta.	Múltiplas falhas do usuário administrador	Parametrizar o SIEM (Graylog) para acionar o

			ocorreram e passaram despercebidas pela gerência do ambiente.	SOC/NOC mediante padrões anômalos de login.
Proteção de Perímetro	Não Conforme	pfSense liberando ICMP e RDP da WAN.	Exposição direta do controlador de domínio a qualquer IP de origem na internet.	Revogar regras <i>any-to-any</i> de entrada na interface WAN do firewall imediatamente.

Fonte: Elaborado pelos Auditores (2026)

15. PRIORIZAÇÃO

Fase 1 - Imediata (Até 48 horas):

- Alterar senhas padrões do Firewall pfSense e revogar permissões de Domain Admin de usuários indevidos.
- Revogar os privilégios de Domain Admin do usuário *acacio.flores* no Active Directory - Risco Alto 15, Impacto máximo (I=5). Conta indevida com acesso administrativo total ao controlador de domínio.
- Bloquear as portas RDP e ICMP para acesso a partir da WAN.

Fase 2 - Curto Prazo (1 a 2 semanas):

- Habilitar o uso exclusivo de HTTPS (certificados digitais seguros) no Graylog e pfSense.
- Corrigir o serviço de ingestão de logs do Graylog para capturar dados atualizados e restringir seu acesso a usuários autenticados.
- Configurar regras avançadas de *threshold* no Graylog para disparar alertas contra tentativas de Força Bruta ou criação de processos elevados.

Fase 3 - Médio Prazo (1 Mês):

- Revisar todos os privilégios de Domain Admin no Active Directory e purgar credenciais armazenadas em texto claro na documentação técnica.
- Promover treinamento de conscientização em segurança da informação para toda a equipe técnica

Tabela 5. Priorização

ID	Ação Recomendada	Responsável Direto	Departamento	Prazo Limite
PA-01	Alterar senhas padrão do pfSense e gerências.	Administrador de Redes	TI / Infraestrutura	24 Horas
PA-02	Revogar Domain Admin do usuário <i>acacio.flores</i> no Active Directory	Gestor de Identidades	TI / Governança	24 Horas

PA-03	Revogar regras <i>any-to-any</i> na WAN e fechar portas RDP/ICMP expostas.	Engenheiro de Segurança	Segurança (SOC)	48 Horas
PA-04	Implementar HTTPS/TLS nos consoles Graylog e pfSense.	Administrador de Sistemas	TI / Infraestrutura	3 Dias
PA-05	Corrigir o serviço de ingestão de logs do Graylog para capturar dados atualizados e restringir seu acesso a usuários autenticados.	Analista de Monitoramento	SOC / NOC	5 Dias
PA-06	Configurar alertas de Força Bruta e Thresholds no Graylog.	Analista de Monitoramento	SOC / NOC	7 Dias
PA-07	Revisar todos os privilégios de Domain Admin no Active Directory e purgar credenciais armazenadas em texto claro na documentação técnica.	Gestor de Identidades	TI / Governança	10 Dias
PA-08	Treinamento de conscientização em segurança para a equipe técnica.	Gestor de TI	RH / Treinamento	30 Dias

Fonte: Elaborado pelos Auditores (2026)

16. REFERÊNCIAS

ASSOCIAÇÃO BRASILEIRA DE NORMAS TÉCNICAS. **ABNT NBR 6023**: Informação e documentação — Referências — Elaboração. Rio de Janeiro: ABNT, 2018.

FACULDADE ACADITI. **MAC-PRO DFAC - Auditoria & Segurança Cibernética**: Auditoria e Monitoramento de Redes, Perímetros e Sistemas. Orientador: Prof. Fábio Sena. São Pedro: Acaditi, 2026.

INTERNATIONAL ORGANIZATION FOR STANDARDIZATION. **ISO/IEC 27001:2022**: Information security, cybersecurity and privacy protection — Information security management systems — Requirements. Genebra: ISO, 2022.

MAC-PRO DFAC. **Relatório Final de Auditoria (RFA)**: Unidade Examinada VirtuaTech — RAI 001/2026. São Pedro: MAC-PRO DFAC, abr. 2026.

MICROSOFT CORPORATION. **Guia de Segurança do Active Directory**: Gerenciamento de identidades e acessos. Redmond: Microsoft, 2026.

NETGATE. **Documentação Técnica do pfSense 2.7.0**: Firewall e Segurança de Perímetro. Austin: Netgate, 2026.

PCI SECURITY STANDARDS COUNCIL. **PCI DSS v4.0.1**: Payment Card Industry Data Security Standard. Wakefield: PCI SSC, 2024.

TORCHLOGIC. **Graylog v.4.0 User Guide**: Centralização e análise de logs para resposta a incidentes. Houston: Graylog, Inc., 2026.

VIRTUATECH. **Política de Monitoramento de Redes e Sistemas da VirtuaTech**: Versão 1.2. São Pedro: VirtuaTech, 2026.

ANEXOS:

- Evidência_Cadeia de custódia.zip
- Cadeia_de_Custodia_VirtuaTech_RAI001_2026_Assinado.pdf